Manuál pro provoz

Verze: 2026.0.3 04.03.2026 9:55:45

Obsah

- Bezpečnost
  - Bezpečnostní testy
  - Kontrola zranitelností knihoven
  - Aktualizace WebJETu
- Audit
  - Audit
  - Seznam notifikací
  - Změněné stránky
  - Čeká na publikování
  - Úrovně logování
  - Log soubory
  - Poslední logy
- Provoz
  - Výkon serveru
  - Monitorování serveru
  - Restartovat
  - Výměna údajů uzlů clusteru
  - Mazání dat
  - Nastavení licenčního čísla
- Soubory
  - Zálohování systému

1. Bezpečnostní testy

Zabezpečení WebJET CMS je podmíněno jeho korektní konfigurací a korektním nastavením přístupových práv. Informace na této stránce je třeba nastavit před spuštěním do produkčního provozu a následně kontrolovat minimálně na kvartální bázi a vždy před provedením bezpečnostních testů.

1.1. Nastavení systému

1.1.1. Skupiny práv

Přes WebJET CMS lze upravovat i programové soubory, proto je třeba před penetračními testy nastavit omezení práv. Doporučujeme vytvořit níže uvedené skupiny práv (https://docs.webjetcms.sk/latest/cs/admin/users/perm-groups). **Jiné skupiny uživatelů, nebo přímo uživatelé, by níže uvedená jednotková práva neměla mít povolena**.

Správa uživatelů

Skupina obsahuje práva, která umožňují modifikovat oprávnění. Uživatel s takovou skupinou práv musí být dostatečně obezřetný a musí mu být jasné, že má nejvyšší možnosti práv (protože dokáže nastavovat práva sám sobě, nebo jiným uživatelům).

Uživatel s takovým právem dokáže kompromitovat celý systém (např. dokáže si nastavit oprávnění tak, že dokáže smazat všechny web stránky, nebo všechny soubory).

Skupině práv nastavte následující práva:

- správa administrátorů - právo umožňuje nastavovat oprávnění uživatelům v administraci
- Skupiny práv - právo umožňuje nastavovat oprávnění na skupiny

Programátor

Standardní nastavení by mělo být takové, že uživatelé (redaktoři) nemohou nahrávat a modifikovat programové soubory. Programátor ale často potřebuje provést rychlou změnu (`hotfix`) programového kódu a potřebuje tedy modifikovat i programové soubory. Zároveň má přidána práva pro změnu všech konfiguračních proměnných a editaci všech překladových textů.

Uživatel s takovým právem dokáže kompromitovat celý systém (např. dokáže nahrát škodlivý kód, který na serveru může provést libovolnou operaci včetně smazání souborů na serveru, nebo kompletního smazání databáze).

- Neomezené nahrávání souborů (přípony a velikosti)
- Konfigurace - zobrazení všech proměnných
- Editace textů - zobrazení všech textů

Poznámka: seznam konf. proměnných bez oprávnění "Konfigurace - zobrazení všech proměnných" se nastavuje v konf. proměnné `configEnabledKeys` , seznam překladových klíčů bez oprávnění "Editace textů - zobrazení všech textů" v konf. proměnné `propertiesEnabledKeys` . V překladových klíčích se zároveň filtruje HTML kód, pravidla nastavení jsou popsána níže v sekci `Stored XSS cez úpravu prekladových kľúčov` .

Kromě oprávnění je třeba povolit přístup k zápisu do adresářů souborového systému:

- `/apps` - obsahuje kód aplikací
- `/components` - obsahuje kód aplikací
- `/templates` - obsahuje designové šablony

Pokud je prostředí nasazováno přímo z GIT repozitáře a nepředpokládáte provedení `hot-fixov` přímo přes WebJET CMS nemusíte výše uvedená práva na zápis do souborového systému nastavovat. Navíc pro tento případ doporučujeme nastavit na souborovém systému oprávnění zápisu pouze pro adresáře (ostatní adresáře a soubory mají oprávnění pouze ke čtení):

- `/images` - obsahuje obrázky nahrané redaktory CMS

- `/files` - obsahuje soubory nahrané redaktory CMS
- `/shared` - obsahuje obrázky a soubory nahrané redaktory CMS sdílené mezi doménami
- `/WEB-INF/tmp` - obsahuje dočasné soubory CMS
- `/WEB-INF/imgcache` - obsahuje generované zmenšeniny a výřezy obrázků pro použití přes `/thumb` prefix
- `/WEB-INF/formfiles` - obsahuje soubory nahrané přes formuláře na web stránce vytvořené přes aplikaci Formuláře

1.1.2. Konfigurace

Nastavte a zkontrolujte následující konfigurační proměnné (v administraci Nastavení->Konfigurace):

- `defaultDisableUpload=true` - aktivuje režim, ve kterém má uživatel práva na souborový systém pouze pro nastavené adresáře. Pokud nemá nastaven žádný adresář nebude mít právo zápisu souboru do žádného adresáře.
- `fbrowserShowOnlyWritableFolders` - po nastavení na `true` se v průzkumníkovi zobrazí pouze soubory na které má uživatel práva, ostatní soubory nebudou ani zobrazeny. Standardně se zobrazují také soubory, na které uživatel nemá práva, není ale možné je modifikovat.
- `emailProtectionSenderEmail` - nastavte vhodnou emailovou adresu typu `noreply@domena.sk`, která se použije jako email adresa odesílaných emailů (původní hodnota se nastaví do `Reply-To` hlavičky emailu).
- `adminEnabledIPs` - obsahuje čárkou oddělený seznam IP adres, ze kterých je povolen přístup do `/admin` části.
- `multidomainAdminHost` - umožňuje nastavit samostatnou doménovou adresu pro přístup do `/admin` části, například. `cms.domena.sk`. Po nastavení bude volání `/admin` adresy na ostatních doménách vracet chybu 404 - Stránka neexistuje.
- `serverBeyoundProxy` - je-li aplikační server za Load Balancerem / proxy je třeba nastavit hodnotu na `true` (jinak nastavte hodnotu `false`). Load Balancer musí následně posílat v HTTP hlavičce `x-forwarded-for` IP adresu návštěvníka web stránky. Jméno lze nastavit v proměnné `xForwardedForHeader` - standardně použije první IP adresu, pokud jméno hlavičky končí na `::last` použije poslední. V hlavičce `x-forwarded-proto` protokol (`http` nebo `https`). Jméno lze nastavit v proměnné `requestIsSecureHeaderName`, Ověřte v auditu (např. po vyplnění formuláře na web stránce) korektní zaznamenání IP adresy návštěvníka web stránky.
- `serverName` - ve výchozím nastavení `unknown` - nastavuje hodnotu HTTP hlavičky `Server` při HTTP odpovědi. Máte-li aplikační server za Load Balancerem/proxy ověřte v HTTP odpovědi hodnotu této hlavičky a případně ji nastavte na Load Balanceru/proxy serveru na vhodnou neznámou hodnotu.
- `pathFilterBlockedPaths` - čárkou oddělený seznam blokovaných URL adres (pokud URL obsahuje daný výraz). Standardně jsou blokovány URL adresy, které v názvu obsahují výraz `.DS_Store,debug.,config.properties,Thumbs.db,.git,.svn`. Můžete přidat další podle potřeby.

Omezení pro nahrávané soubory redaktory v administraci:

- `FCKConfig.UploadMaxSize[Default][image]` - ve výchozím nastavení 0 - limit velikosti v kB pro nahrávání **obrázků**, doporučujeme nastavit na hodnotu nap. 10000 pro nahrání max. 10 MB obrázku
- `FCKConfig.UploadMaxSize[Basic][image]` - ve výchozím nastavení 2048 - limit velikosti v kB pro nahrávání **obrázků** pro uživatele, který **nemají právo Kompletní menu v editoru**
- `FCKConfig.UploadMaxSize[Default][file]` - ve výchozím nastavení 0 - limit velikosti v kB pro nahrávání **souborů**, doporučujeme nastavit na hodnotu nap. 50000 pro nahrání max. 50 MB souboru
- `FCKConfig.UploadMaxSize[Basic][file]` - ve výchozím nastavení 2048 - limit velikosti v kB pro nahrávání **souborů** pro uživatele, který **nemají právo Kompletní menu v editoru**
- `FCKConfig.UploadFileTypes[Default][image]` - ve výchozím stavu prázdné = bez omezení - limity typů **obrázků**, doporučujeme nastavit na hodnotu `jpg,jpeg,png,gif,svg,mp3,mp4`. Možnost povolení přípony SVG je třeba zvážit, viz potencionální riziko níže v bloku `Stored XSS cez SVG obrázok`.
- `FCKConfig.UploadFileTypes[Basic][image]` - ve výchozím nastavení `jpg,jpeg,png,gif,mp4` - limity typů **obrázků** pro uživatele, který **nemají právo Kompletní menu v editoru**
- `FCKConfig.UploadFileTypes[Default][file]` - ve výchozím stavu prázdné = bez omezení - limity typů **souborů**, doporučujeme nastavit na hodnotu `pdf,docx,xlsx,pptx,ppsx,zip,rtf`
- `FCKConfig.UploadFileTypes[Basic][file]` - ve výchozím nastavení `doc,docx,xls,xlsx,pdf,zip,rtf` - limity typů **souborů** pro uživatele, který **nemají právo Kompletní menu v editoru**

Můžete zkontrolovat ještě následující konf. proměnné:

- `overviewJsonUrl` - definuje URL adresu, ze které se čte seznam novinek ve WebJETu. Pokud uživatelé nemají dostupný internet z prohlížeče, můžete nastavit na hodnotu `/admin/v9/json/` pro čtení z lokální instance. Uživatelé ale nebudou vidět novinky v nových verzích WebJET CMS.
- `springSecurityAllowedAuths` - seznam povolených metod autorizace pro REST služby, ve výchozím nastavení `basic,api-token`. Pokud projekt nepotřebuje jiné než standardní přihlášení přes formulář, nastavte na prázdnou hodnotu. Po změně hodnoty je třeba restartovat aplikační server.

1.1.3. HTTP hlavičky

V aplikaci Konfigurace můžete nastavit hodnoty bezpečnostních hlaviček:

- `contentSecurityPolicy` - nastavení hlavičky `Content-Security-Policy`. Omezení jak má stránka načítat různé zdroje. Máte-li httpS certifikát můžete nastavit na hodnotu: `default-src 'none'; script-src https: blob: data: 'unsafe-inline' 'unsafe-eval'; worker-src https: blob:; child-src https` Ve výchozím nastavení prázdné (hlavička se nenastavuje).
- `contentSecurityPolicySvg` - specifické omezení pro SVG obrázky z důvodu jejich jiného zpracování v Internet Explorer.
- `featurePolicyHeader` - hodnota HTTP hlavičky `Feature-Policy/Permissions-Policy` (např.: `microphone 'none'; geolocation 'none'`), více na: https://developer.mozilla.org/en-US/docs/Web/HTTP/Feature_Policy (https://developer.mozilla.org/en-US/docs/Web/HTTP/Feature_Policy). Ve výchozím nastavení prázdné.
- `refererPolicy` - nastavení HTTP hlavičky `Referrer-Policy`, doporučujeme nastavit na hodnotu `same-origin`. Ve výchozím nastavení `same-origin`.
- `serverName` - hodnota hlavičky `Server` v HTTP odpovědích. Ve výchozím nastavení `unknown`. Nelze nastavit na prázdnou hodnotu, protože pak tam vloží hlavičku aplikační server.
- `strictTransportSecurity` - ve výchozím stavu prázdné - nastavuje HTTP hlavičku Strict-Transport-Security (https://en.wikipedia.org/wiki/HTTP_Strict_Transport_Security) v HTTP odpovědích, což zajistí přesměrování HTTP požadavků na zabezpečený httpS, doporučujeme nastavit na hodnotu: `max-age=31536000 ; includeSubDomains`. Vyžaduje, aby aplikační server byl dostupný přes zabezpečený httpS protokol.
- `xContentTypeOptions` - hodnota hlavičky `X-Content-Type-Options` pro nastavení určování typů souborů podle obsahu (ignorování přípony). Ve výchozím nastavení `nosniff`.
- `xFrameOptions` - hodnota hlavičky `X-Frame-Options` pro ochranu před CSRF útokem. Ve výchozím nastavení `SAMEORIGIN`.
- `xRobotsTagValue` - hodnota hlavičky `X-Robots-Tag` pro URL adresy nastavené v proměnné `xRobotsTagUrls`. Ve výchozím nastavení `noindex, nofollow`.
- `xRobotsTagUrls` - seznam začátků URL adres oddělených čárkou pro nastavení hlavičky `X-Robots-Tag`. Pokud seznam obsahuje hodnotu `NOT_SEARCHABLE_PAGE` nastaví se hlavička i pro stránky, které mají vypnuté vyhledávání. Ve výchozím nastavení `/components/,NOT_SEARCHABLE_PAGE`.
- `xXssProtection` - hodnota hlavičky `X-XSS-Protection` pro ochranu před XSS útokem. Ve výchozím nastavení `1; mode=block`.

Nastavení hlavičky `Access-Control` pro přístup k REST službám z jiných serverů:

- `accessControlAllowOriginValue` - hodnota hlavičky `Access-Control-Allow-Origin` pro URL nastaveno v proměnné `accessControlAllowOriginUrls`. V hodnotě můžete použít makro (viz níže). Výchozí nastavení na `{HTTP_PROTOCOL}://{SERVER_NAME}:{HTTP_PORT}`.
- `accessControlAllowOriginUrls` - seznam začátků URL adres oddělených čárkou pro nastavení hlavičky `Access-Control-Allow-Origin`. Výchozí nastavení na `/rest/,/private/rest/,/admin/rest/`.
- `accessControlAllowHeaders` - hodnota pro nastavení hlavičky `Access-Control-Allow-Headers`, nastavuje se jen při generování hlavičky `Access-Control-Allow-Origin`. Ve výchozím nastavení `Origin, Accept, X-Requested-With, Content-Type, Access-Control-Request-Method, Access-Control-Request-Headers, x-csrf-tok`
- `accessControlAllowMethods` - hodnota pro nastavení hlavičky `Access-Control-Allow-Methods`, nastavuje se jen při generování hlavičky `Access-Control-Allow-Origin`. Ve výchozím nastavení `HEAD,POST,GET,OPTIONS,PUT`.
- `accessControlMaxAge` - hodnota pro nastavení hlavičky `Access-Control-Max-Age`, nastavuje se jen při generování hlavičky `Access-Control-Allow-Origin`. Ve výchozím nastavení `1800`.
- `accessControlAllowedOrigins` - není-li prázdné, vyžaduje při požadavku hlavičku `origin`, jejíž hodnota se musí nacházet v tomto seznamu (čárkou/novým řádkem oddělený seznam). Nastavuje se jen při generování hlavičky `Access-Control-Allow-Origin`. Ve výchozím nastavení prázdné.

Pokud potřebujete nastavit jinou HTTP hlavičku můžete použít aplikaci HTTP hlavičky (https://docs.webjetcms.sk/latest/cs/admin/settings/response-header/README) v sekci Nastavení.

V hodnotě můžete použít makro `{HTTP_PROTOCOL}, {SERVER_NAME}/{DOMAIN_NAME}/{DOMAIN_ALIAS}, {HTTP_PORT}`, které bude nahrazeno za hodnotu získanou na serveru. `SERVER_NAME` je doménové jméno z `request.getServerName()`, `DOMAIN_NAME` a `DOMAIN_ALIAS` jsou hodnoty domén nebo alias-u nastaveny ve web stránkách. Hodnota `{INSTALL_NAME}` reprezentuje jméno instalace. Hodnota `{HEADER_ORIGIN}` obsahuje hodnotu HTTP hlavičky `origin`.

Ve starších instalacích bylo možné nastavit HTTP hlavičky i přes konf. proměnnou `responseHeaders` ve které umíte nastavit hlavičku pro URL prefix (začátek URL adresy). Na každý řádek zadáte hodnotu ve formátu: `url-prefix:hlavička:hodnota`, například:

```txt
/admin:X-Accel-Buffering:no
/rest/calculators/:Access-Control-Allow-Origin:*
/rest/calculators/:Access-Control-Allow-Headers:origin,x-requested-with,access-control-request-headers,content-type,access-control-request-method,accept,x-csrf-token
/rest/calculators/:Access-Control-Allow-Methods:GET,OPTIONS
```

Hodnoty nastavené přes konf. proměnnou `responseHeaders` jsou globální bez ohledu na aktuální doménu.

1.1.4. Pravidla hesel

Pravidla pro hesla lze nastavit přes následující konfigurační proměnné (u proměnné je v závorce uvedena standardní hodnota):

- `passwordAdminMinLength` - Určuje minimálně jaké délky má být heslo pro administrátora (5).
- `passwordAdminMinCountOfSpecialSigns` - Určuje minimální počet výskytu speciálních znaků v hesle pro administrátora (0).
- `passwordAdminMinUpperCaseLetters` - Určuje minimální počet výskytu velkých písmen v hesle pro administrátora (1).
- `passwordAdminMinLowerCaseLetters` - Určuje minimální počet výskytu malých písmen v hesle pro administrátora (0).
- `passwordAdminMinCountOfDigits` - Určuje minimální počet výskytu čísel v hesle pro administrátora (1).
- `passwordAdminExpiryDays` - Určuje počet dní platnosti hesla pro administrátora. Po uplynutí času, bude uživatel vyzván si změnit heslo. Hodnota 0 znamená, že se nekontroluje expirace hesla (0).

Podobně lze nastavit pravidla hesel i pro přihlášení do zabezpečené zóny web stránky (ne administrace), proměnné jsou stejné, ale neobsahují výraz `Admin`. Čili jméno proměnné je například. `passwordMinUpperCaseLetters`.

Nastavením konfigurační proměnné `isGoogleAuthRequiredForAdmin` na `true` bude pro přístup do `/admin` části vyžadována dvou faktorové ověřování. Každý uživatel ji předem musí nastavit v administraci kliknutím na své jméno vpravo nahoře a zvolením možnosti **Dvoustupňové ověřování**, respektive otevřením stránky `/admin/2factorauth.jsp`.

Dvoustupňové ověřování doporučujeme nastavit minimálně na všechny účty, přes které lze spravovat uživatelské účty a práva a nastavovat konfiguraci systému.

WebJET kontroluje při změně hesla historii a nepovoluje opakovaně použít stejné heslo. Ovlivňují to následující konf. proměnné:

- `passwordHistoryLength` - počet použitých hesel uživatele, která se pamatují v historii (výchozí 6).
- `passwordHistoryEnabled` - pokud je nastaveno na `true` je kontrolována v databázi i historie hesel a není povoleno při změně hesla použít takové, které bylo v minulosti (výchozí `true`).

Při požadavku na změnu hesla jsou použity následující proměnné:

- `passwordResetValidityInMinutes` - časová platnost v minutách pro zaslaný odkaz na změnu hesla (výchozí 30).
- `changePasswordPageUrl` - adresa stránky pro změnu hesla (výchozí `/components/user/change_password.jsp`).

1.1.5. Blokování přihlášení

Po nesprávné kombinaci jména a hesla WebJET blokuje další přihlášení ze stejné IP adresy. Lze nastavit následující konf. proměnné:

- `logonBlockedDelay` - čas v sekundách, během kterých nebude možné se znovu přihlásit po zadání špatného jména/hesla (výchozí 10).
- `logonBlockedAfterUnsuccessCount` - počet neúspěšných přihlášení po kterých se aplikuje zdržení definované v `logonLoginBlockedDelay` (výchozí 5).
- `logonLoginBlockedDelay` - čas v sekundách, během kterých nebude možné znovu se přihlásit po zadání špatného hesla a `logonBlockedAfterUnsuccessCount` počtu neúspěšných přihlášení pro zadané přihlašovací jméno (výchozí 60).

Standardně se tedy aplikuje hodnota 10 sekund (`logonBlockedDelay`), pokud se zadá za sebou více než 5 krát (`logonBlockedAfterUnsuccessCount`) aplikuje se zdržení 60 sekund (`logonLoginBlockedDelay`).

Během doby blokování přihlášení se nadále nezvyšuje počítadlo neúspěšných pokusů a neprodlužuje se čas, protože nedochází vůbec k volání kódu přihlašování.

Můžete zapnout režim **pouze jednoho aktivního přihlášení** na **jednoho uživatele**. Zapnete jej nastavením konfigurační proměnné `sessionSingleLogon` na hodnotu `true` . Při novém přihlášení uživatele se zruší ostatní `session` daného uživatele. Podporován je i běh v režimu cluster, kdy se zruší `session` na všech uzlech clusteru. Takové nastavení je vhodné i jako ochrana před sdílením přihlašovacích údajů mezi více uživateli.

1.1.6. Algoritmus hashování hesel

Od verze `2022.40` se používá k hashování hesel algoritmus BCrypt v implementaci `org.springframework.security.crypto.bcrypt.BCrypt` .

Možná nastavení:

- `bcryptSaltRounds` (výchozí 12) - log2 počtu opakování saltování
- `passwordHashAlgorithm` (výchozí `bcrypt`) - jméno algoritmu pro hashování, možné hodnoty `bcrypt` nebo `sha-512` .

Starší verze používaly algoritmus `SHA-512` se 100 násobným opakováním. Starší hash hodnoty hesla se změní na `bcrypt` algoritmus při změně hesla uživatele. Chcete-li vynutit změnu algoritmu můžete nastavit konf. proměnnou `passwordAdminExpiryDays` na nenulovou hodnotu, což vyvolá požadavek na změnu hesla po přihlášení uživatele.

1.1.7. Přihlašování do administrace

Přihlašování do administrace ovlivňují již i výše zmíněné konfigurační proměnné:

- `adminEnabledIPs` - obsahuje čárkou oddělený seznam IP adres, ze kterých je povolen přístup do `/admin` části.
- `multidomainAdminHost` - umožňuje nastavit samostatnou doménovou adresu pro přístup do `/admin` části, například `cms.domena.sk` . Po nastavení bude volání `/admin` adresy na ostatních doménách vracet chybu 404 - Stránka neexistuje.
- `isGoogleAuthRequiredForAdmin` - zapnutí dvou faktorového ověřování při přihlášení do administrace `/admin` .
- `clusterMyNodeType` - v případě clusteru nastavuje režim uzlu, jen uzly nastavené na hodnotu `full` obsahují administraci a umožňují přihlášení do ní.
- `auditDontLogUsrlogon` - po nastavení na `true` se nebude auditovat běžné (nikoli administrátorské) přihlášení uživatele. Vhodné na vysoce zatížený intranet kde to zbytečně zahlcuje audit (výchozí `false`).

Uživatel, který se úspěšně autorizuje, musí navíc splňovat následující kritéria:

- `Schválený používateľ` - účet musí mít zvolenou uvedenou možnost.
- `Začiatok platnosti` - je-li zadaná hodnota musí být starší než aktuální datum.
- `Koniec platnosti` - je-li zadaná hodnota musí být větší než aktuální datum.
- `Povoliť vstup do admin sekcie (správa web sídla)` - účet musí mít povolenou uvedenou možnost, jinak není možný přístup do administrace.

V případě speciálních požadavků na přihlašování/ověřování uživatele je možné implementovat vlastní Java třídu přihlašování a nastavit ji přes konf. proměnnou `adminLogonMethod` . Následně se použije zadaná Java třída namísto standardního přihlášení.

Při přihlašování se při nesprávných údajích blokuje přihlášení.

1.1.8. Ověřování vůči LDAP serveru

Při ověřování uživatele vůči LDAP serveru lze nastavit následující konf. proměnné:

- `ldapProviderUrl` - URL adresa LDAP serveru pro přihlašování přes LDAP ve tvaru `ldap://ldap.local:389/DC=firma,DC=com??base`.
- `ldapPassword` - přihlašovací jméno technického uživatele pro získání údajů z LDAP.
- `ldapUsername` - přihlašovací heslo technického uživatele pro získání údajů z LDAP.
- `ldapUseSslProtocol` - použije SSL při komunikaci s LDAP serverem. Je třeba mít povoleno SSL na portu 636 LDAP serveru. Pokud se používá ldapS://, nechat hodnotu na false.
- `NTLMForbiddenURL` - URL adresa zamítnutého přístupu (výchozí `/500.jsp`).
- `NTLMDomainController` - jméno doménového řadiče.
- `ldapDomainAppend` - je-li třeba přihlašování s celou doménou zde je možné zadat její doplnění k zadanému přihlašovacímu jménu uživatele.
- `ldapSecurityPrincipalDn` - nastaví pro LDAP speciální `SECURITY_PRINCIPAL` Např. `cn=!USERNAME!,dc=ad,dc=interway,dc=sk` s tím, že `!USERNAME!` zamění za přihlašovací jméno. Pokud je prázdné použije se `ldapUsername+ldapDomainAppend`.
- `ldapFilter` - přihlašovací filtr pro LDAP přihlašování se kterým se provede vyhledání účtu (výchozí `(&(objectClass=Person) (&(sAMAccountName=!USERNAME!)))`).
- `basicNtlmLogonAttrs` - seznam atributů, které se mají číst z LDAP serveru při přihlašování. Pokud je prázdné, ověří se pouze přihlášení a uživatel se neaktualizuje hodnotami v LDAP serveru. Ve výchozím nastavení `mail,title,givenName,sn,streetAddress,l,postalCode,co,company,telephoneNumber,mobile,description,memberOf,distinguishedNa`
- `ntlmDefaultUserPhoto` - pokud je zadáno na neprázdnou hodnotu a uživatel nemá v LDAP fotografii nastaví fotku podle zadané URL adresy.

Nastavení práv:

Po přihlášení se automaticky kontroluje shoda jména skupiny uživatelů a skupiny práv vůči skupinám v LDAP (atribut `memberOf`). Pokud se jméno shoduje skupina ve WebJETu se uživateli přiřadí. Kromě toho lze nastavit:

- `NTLMAdminGroupName` - jméno skupiny v LDAP která identifikuje, že účet má přístup do administrace (např. WebJETAdmins).
- `passwordProtectedAutoId` - čárkou oddělený seznam ID skupin uživatelů, které budou přiřazeny automaticky uživateli po úspěšném přihlášení.

1.1.9. Konfigurace aplikačního serveru Tomcat

Předpokládáme, že web stránka/aplikace bude dostupná přes zabezpečený httpS protokol. Proto je třeba nastavit atribut `secure="true"`, HTTP/AJP konektoru (https://tomcat.apache.org/tomcat-9.0-doc/config/http.html), aby session cookie byla dostupná pouze přes zabezpečený httpS protokol. Nastavení provedete v souboru `tomcat/conf/server.xml`. Atribut `useBodyEncodingForURI="true"` nastavuje stejné kódování znaků pro URL adresu jako je použito pro tělo stránky.

```xml
<Connector
    ...
    secure="true"
    useBodyEncodingForURI="true"
    ...
/>
```

pokud použijete nezabezpečený HTTP protokol nebude session cookie v prohlížeči akceptována a session nebude držena (projeví se to opakovaným zobrazením přihlašovacího okna hned po zadání správných přihlašovacích údajů).

Aby se při zobrazení chyby nezobrazila verze aplikačního serveru `Tomcat` a `Stack Trace` je třeba v server.xml do `<Host` elementu přidat konfiguraci ErrorReportValve (https://tomcat.apache.org/tomcat-9.0-doc/config/valve.html#Error_Report_Valve):

```xml
<Host ...>
    <Valve className="org.apache.catalina.valves.ErrorReportValve"
        showReport="false"
        showServerInfo="false" />
</Host>
```

v případě potřeby můžete vytvořit i statickou html stránku v kódování `utf-8` s chybovou zprávou a nakonfigurovat ji jako:

```xml
<Valve className="org.apache.catalina.valves.ErrorReportValve"
    errorCode.400="webapps/error400.html"
    errorCode.0="webapps/errorOthers.html"
    showReport="false"
    showServerInfo="false" />
```

V konfiguračním souboru `server.xml` doporučujeme správně nastavit možnost `defaultHost`. Útočníci mohou modifikovat hlavičku `Host` a tedy směřovat požadavek z internetu například. na administrační host, který nemusel být z internetu dostupný (pokud na jednom aplikačním serveru běží administrační i veřejný uzel clusteru). Příkladem je použití `localhost`, které může být přiřazeno k administračnímu serveru a tedy upravený požadavek může skončit na administračním nodu.

Hodnotu `defaultHost` doporučujeme směřovat na neexistující `<Host` element, v takovém případě vyhlásí aplikační server chybu, že takový `host` nezná. Aplikační server tedy nezpracuje neznámé domény. Nevýhoda takového řešení je, že po přidání nové domény je třeba ji přidat jako `<Alias` i do aplikačního serveru.

Pokud používáte Load Balancer je třeba zajistit, aby na aplikační server posílal jen známé (whitelist) domény. Pro neznámé domény musí odpovídat chybou.

```xml
<Engine name="Catalina" defaultHost="localhost">

    <Host name="localhost"...>
        <Alias>admin.domain.eu</Alias>
    </Host>
```

1.1.10. Notifikace při změně

Doporučujeme nastavit notifikace posílané bezpečnostnímu technikovi na následující typy událostí:

- `CONF_UPDATE` a `CONF_DELETE` - změna/smazání konfigurační proměnné
- `PROP_UPDATE` a `PROP_DELETE` - změna/smazání překladového klíče (přes překladový klíč lze vkládat i JavaScript kód)

Notifikace nastavíte v administraci v části Audit->Notifikace. Bezpečnostní technik bude mít přehled o těchto změnách a v případě podezření na útok může zareagovat.

1.1.11. Bezpečnost serveru

Důležitá je i bezpečnost samotného serveru a použitého softwaru. Aktualizujte software na aktuálně podporované verze. Vhodné je instalovat na server i antivirus, který bude kontrolovat nahrávané soubory a v případě detekce viru v souboru zamezí k tomuto souboru přístup.

1.2. Nastavení Load Balanceru

Pokud je před aplikačními servery předřazen Load Balancer je třeba zajistit:

- Směrovat na aplikační server pouze definované domény, aby nemohl nastat útok modifikováním `Host` hlavičky. Load Balancer nesmí povolit poslání neznámé domény na aplikační server.
- WebJET přebírá nastavení IP adresy z HTTP hlavičky `X-Forwarded-For` při nastavení konfigurační proměnné `serverBeyoundProxy=true`. Je tedy třeba zajistit, aby taková HTTP hlavička neprocházela z internetu, ale Load Balancer ji vždy přepsal na korektní hodnotu - IP adresu návštěvníka. Totéž platí pro HTTP hlavičku `x-forwarded-proto`. Nesprávné nastavení záhlaví může vést ke zpřístupnění částí, které jsou povoleny pouze pro specifické IP adresy, jako například administrace.

1.3. Nastavení WAF

Pokud je před aplikačním serverem předřazen `Web Application Firewall/WAF` je třeba nastavit **výjimky pro administraci**. Některé HTTP požadavky v administraci mohou být detekovány jako útok typu XSS/SQL Injection, protože HTTP požadavek může odesílat JavaScript kód, nebo SQL příkaz. Příkladem je ukládání web stránky, kde v poli HTML kód do hlavičky může být vložen potřebný JavaScript kód nebo ukládání záznamů v aplikaci Skripty, kde se přímo vkládá JavaScript kód.

Ideální řešení je použít cluster řešení s dedikovaným CMS uzlem v lokální síti, který je nedostupný z vnějšího prostředí. Pro tento případ lze WAF pro CMS nod nepoužít.

Administrace používá REST služby začínající na URL adresu `/admin/rest`, viz doporučení pro pravidla URL adres (https://docs.webjetcms.sk/latest/cs/custom-apps/spring/rest-url). Na WAF je třeba nastavit výjimky pro URL adresy začínající na:

- `/admin/rest/web-pages` - ukládání web stránek
- `/admin/rest/components/insert-script` - aplikace Skripty
- `/admin/v9/settings/translation-keys` - překladové klíče - v některých případech může být nutné vkládat HTML kód do překladového klíče
- `/admin/rest/settings/configuration` - konfigurace, platí podobné jako pro překladové klíče
- `/admin/searchall.jsp` - vyhledávání v administraci, může být nutné hledat i HTML/JavaScript výraz
- `/admin/replaceall.jsp` - nahrazení výrazu v administraci, platí podobné jako pro vyhledávání
- `/admin/updatedb.jsp` - provedení zadaného SQL příkazu

Další URL adresy je vhodné nastavit na základě používaných aplikací.

1.4. Řešení bezpečnostních nálezů

- `Sensitive Data Exposure`

Prostřednictvím chybových odpovědí se serveru se podařilo odhalit typ a verzi použitého webového serveru.

Řešení: ověřte nastavení HTTP hlavičky `Server`, ve WebJETu lze přestavit v konfigurační proměnné `serverName`, viz výše.

- `RCE via uploaded JSP file`

WebJET CMS umožňuje nahrávání libovolných souborů včetně souborů typu JSP, které umožňují provádění libovolných příkazů na běžícím serveru.

Chybě lze zabránit nastavení práv pro nahrávání souborů, nebo úplným zamezením zápisu programových souborů.

Řešení: upravte nastavení práv pro nahrávání souborů přes konfigurační proměnné `FCKConfig.Upload*`, viz výše.

- `MaliciousFileUpload`

Na serveru chybí antivirová kontrola, je tedy možné na server nahrát škodlivé soubory.

Řešení: nainstalujte na server antivirus.

- `Missing Secure cookie flag`

Session cookie (`JSESSIONID`) nemá nastaven bezpečnostní atribut `Secure` .

Řešení: zkontrolujte a nastavte `secure` atribut v souboru server.xml (https://tomcat.apache.org/tomcat-9.0-doc/config/http.html) aplikačního serveru Tomcat, viz výše.

- `Missing HTTP Strict Transport Security policy`

Aplikace nenastavuje HTTP hlavičku `Strict Transport Security` .

Řešení: hodnotu hlavičky Strict Transport Security (https://en.wikipedia.org/wiki/HTTP_Strict_Transport_Security) lze nastavit v konfigurační proměnné `strictTransportSecurity=max-age=31536000 ; includeSubDomains` , viz. výše.

- `Stored XSS cez SVG obrázok`

SVG soubor umožňuje vložit do těla i JavaScript kód, v případě přímého zobrazení takového souboru v prohlížeči se JavaScript kód provede (při standardním vložení přes `img` se kód neprovede a zobrazení je bezpečné).

Řešení: omezit možnost nahrávání SVG souborů, viz nastavení práv výše. Jak ochranu WebJET CMS generuje pro soubory typu SVG HTTP hlavičku `Content-Security-Policy` s hodnotou `default-src 'self'` , která zamezí provedení javascript kódu (https://github.com/digininja/svg_xss) při přímém zobrazení obrázku. Hodnota je nastavitelná přes konfigurační proměnnou `contentSecurityPolicySvg` .

Pro ověření chování vytvořte SVG soubor s následujícím obsahem, nahrajte jej do WebJET CMS a vložte do testovací stránky a ověřte jeho zobrazení a (ne)provedení XSS útoku:

```xml
<?xml version="1.0" standalone="no"?>
<!DOCTYPE svg PUBLIC "-//W3C//DTD SVG 1.1//EN" "http://www.w3.org/Graphics/SVG/1.1/DTD/svg11.dtd">
<svg version="1.1" baseProfile="full" xmlns="http://www.w3.org/2000/svg"> <polygon id="triangle" points="0,0
0,100 100,0" fill="#3e70b7"
stroke="#004400"/>
<script type="text/javascript">
alert("SVG XSS");
</script>
</svg>
```

- `Stored XSS` přes úpravu překladových klíčů

Přes překladové texty je redaktor schopen provést útok typu `Cross Site Scripting` vůči ostatním návštěvníkům webu, nebo jiným administrátorům.

Překladové klíče se používají také pro vkládání HTML kódu (např. odkazu na obchodní podmínky v kalkulačce, zvýraznění tučným písmem, nastavení CSS stylů), proto tato aplikace technicky umožňuje vkládat i HTML/JavaScript kód (jedná se o vlastnost, nikoli chybu). Třeba si uvědomit, že redaktor může vložit JavaScript kód i přímo v editoru stránek, není zásadní důvod mu v tom zabraňovat iv editaci překladových klíčů.

Řešení: Minimalizovat počet uživatelů s přístupem k aplikaci Překladové texty. Zároveň uživatelé, kteří nemají právo „Editace textů – zobrazení všech textů“ mají omezené možnosti editace. Mohou editovat jen vybrané klíče (nastavené přes konf. proměnnou `propertiesEnabledKeys`) a zároveň upravená hodnota je filtrována a povolí pouze definované HTML značky a atributy. Ty se nastavují v konf. proměnné `propAllowedTags` kde jsou standardně povoleny značky `p,div,a,sub,sup,br,strong` a atributy v konf. proměnné `propAllowedAttrs` kde jsou standardně povoleny atributy `href,src,style,class,rel` . Chcete-li zcela zabránit možnosti vkládání HTML kódu pro uživatele bez oprávnění "Editace textů - zobrazení všech textů" můžete nastavit konf. proměnnou `propAllowedTags` na prázdnou hodnotu (nebo znak `-`). Nastavením na znak `*` se ochrana vypne.

Zároveň jako další ochranu doporučujeme nastavit notifikace při změně na bezpečnostního technika, viz výše.

- `Insecure Deserialization`

Import web stránek obsahuje .xml dokumenty se serializovanými java objekty. Tyto .xml dokumenty lze však změnit a podstrčit vlastní serializované java objekty typu `<object class="java.lang.Runtime" method="getRuntime">`, které provedou zadanou operaci přímo na serveru.

Pro úspěšnou exploitaci je třeba upravit konf. proměnnou `XMLDecoderAllowedClasses`, která obsahuje seznam povolených deserializovaných objektů a přidat tam hodnotou `java.lang.Runtime`.

Řešení: běžný uživatel nesmí mít oprávnění k úpravě konfiguračních proměnných, ty by měla upravovat pouze vyhrazena osoba. Jako další ochranu jsme přímo do kódu (bez možnosti upravit tento seznam) doplnili nepovolené typy objektů, které nelze přes konfiguraci přidat (povolit).

- `Cookies: Set the 'SameSite' flag as a counter measure to cross-site request forgery`

Pro `cookies` lze nastavit atribut SameSite (https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Set-Cookie/SameSite) pro zamezení posílání cookies při CSRF útoku (zamezení posílání cookies jiným doménám).

Aktuálně se v `servlet-api` připravuje podpora nastavení této hodnoty ve verzi 5.x, což může znamenat dlouhé čekání na přímou podporu při programování. Při použití Apache Tomcat je ale možné tuto hodnotu nastavit v konfiguraci pomocí CookieProcessor (https://tomcat.apache.org/tomcat-8.5-doc/config/cookie-processor.html), který ve standardní implementaci umožňuje hodnotu nastavit:

```xml
<Context>
    ...
    <CookieProcessor sameSiteCookies="strict"/>
</Context>
```

2. Kontrola zranitelností knihoven

Pomocí nástroje OWASP Dependency-Check (https://jeremylong.github.io/DependencyCheck/index.html) můžete jednoduše kontrolovat zranitelnosti v Java a JavaScript knihovnách web aplikace. Ty doporučujeme kontrolovat na pravidelné bázi.

Máte-li přístup ke zdrojovému kódu/gradle projektu můžete spustit analýzu přímo pomocí gradlew příkazu (https://docs.webjetcms.sk/latest/cs/developer/backend/security).

Nástroj je ale možné spustit i nad vygenerovaným `war` archivem web aplikace. Nainstalujte si verzi nástroje pro příkazový řádek (https://jeremylong.github.io/DependencyCheck/dependency-check-cli/index.html).

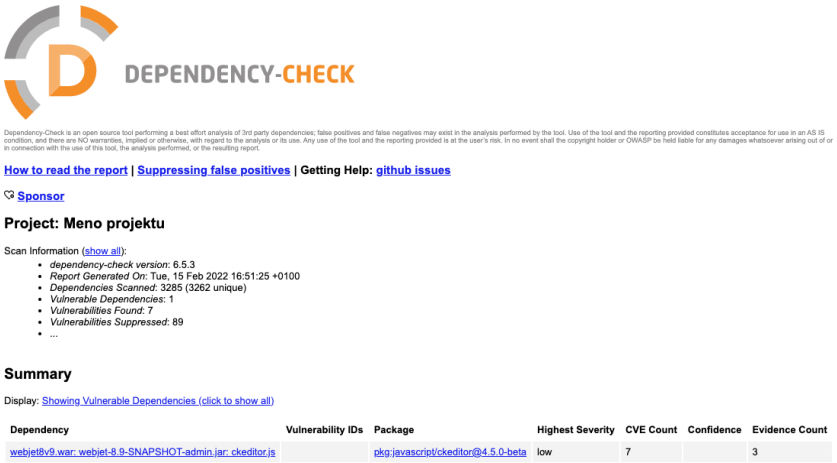
Následně můžete spustit kontrolu pomocí příkazu:

```sh
dependency-check --project "Meno projektu" --suppression dependency-check-suppressions.xml --suppression
dependency-check-suppressions-project.xml --scan build/libs/*.war
```

parametry se nastavuje:

- `--project` - jméno projektu, které se zobrazí v reportu.
- `--suppression` - cesta k souborem s výjimkami (https://docs.webjetcms.sk/latest/cs/developer/backend/security), typicky je tento soubor součástí git repozitáře.
- `--scan` - cesta k souboru/adresáři, který má být analyzován.

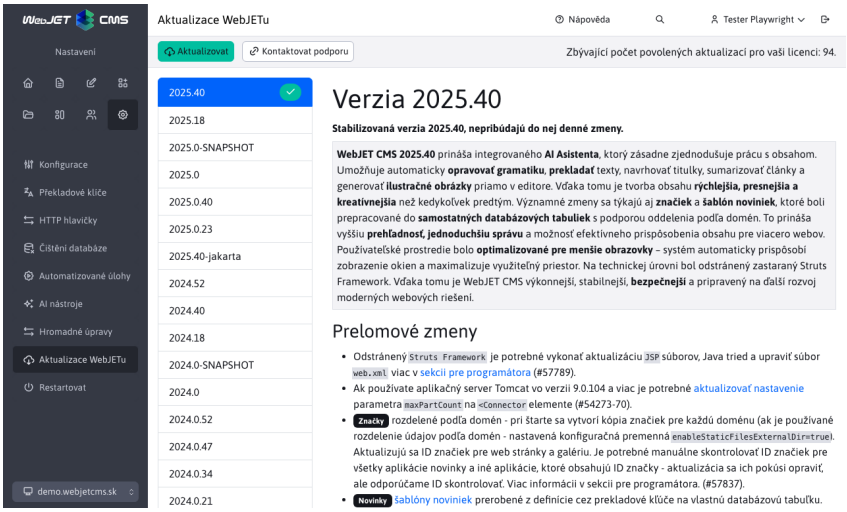
Výsledkem je soubor `dependency-check-report.html` v aktuálním adresáři.



3. Aktualizace WebJETu

Sekce Aktualizace WebJETu slouží k aktualizaci verzí WebJETu. Levá část obrazovky zobrazuje seznam dostupných verzí WebJETu na které lze Váš WebJET aktualizovat. Právě aktuální verze Vašeho WebJETu je v seznamu označena ikonou .

Při kliknutí na jednotlivé verze se v pravé části obrazovky zobrazí seznam všech změn, které vybraná verze přináší.



> **Upozornění:** aktualizaci WebJETu provádějte pouze v případě, že víte co děláte. Před aktualizací kontaktujte vašeho poskytovatele hostingu pro případnou podporu. Může se stát, že po aktualizaci WebJET nenastartuje správně a bude nutný restart serveru.

Pokud váš projekt obsahuje doplňkové JAR knihovny je třeba je umístit i do složky `/WEB-INF/lib-custom/`. Během aktualizace je plně nahrazená složka `/WEB-INF/lib/` a tedy vaše knihovny by byly smazány. To může mít za následek neschopnost spuštění po restartu. Pokud taková situace nastane zkopírujte chybějící knihovny do `/WEB-INF/lib/` ze zálohy.

3.1. Aktualizace na konkrétní verzi

Pro aktualizování WebJETu na konkrétní verzi je třeba zvolit požadovanou verzi a následně použít tlačítko pro spuštění aktualizace

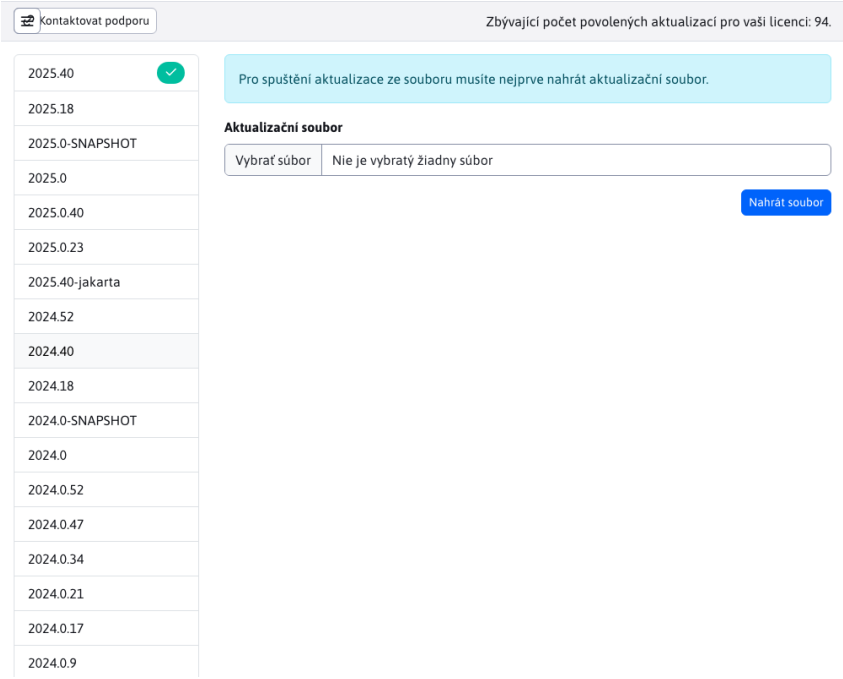
3.2. Aktualizování ze souboru

Podporována je také možnost využít aktualizování ze souboru. Tuto možnost lze vybrat také v levém menu jako

.

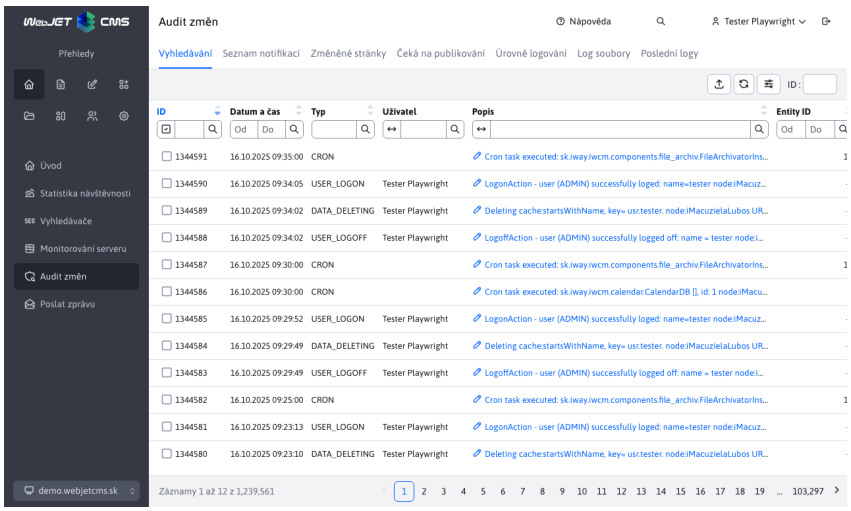
Následně budete vyzváni k výběru a následnému nahrání souboru pomocí tlačítka

. Pokud bude soubor úspěšně nahrán, budete vyzváni ke spuštění samotné aktualizace pomocí tlačítka .



4. Audit

Aplikace Audit je nástroj pro sledování změn v systému. Sekce Audit -> Vyhledávání umožňuje zobrazit a filtrovat jednotlivé zaznamenané hodnoty. Filtrování je možné podle typu auditních záznamů, času, uživatele atp.



5. Typy auditních záznamů

Každý auditní záznam automaticky zaznamená datum a čas, ID přihlášeného uživatele, IP adresu a pokud je povolen reverzní DNS server i jméno počítače. Do textu auditního záznamu se automaticky vkládá jméno uzlu clusteru, URI adresa, doména a hodnota http hlavičky User-Agent.

- `ADMINLOG_NOTIFY` - změna v seznamu notifikací v aplikaci Audit.
- `BANNER` - operace v aplikaci Bannerový systém
- `BASKET` - operace v aplikaci Elektronický obchod
- `CALENDAR` - operace v aplikaci Kalendář událostí
- `CONF_DELETE` - smazání konfigurační proměnné, zaznamená její jméno
- `CONF_UPDATE` - změna nebo přidání konfigurační proměnné (v sekci Nastavení), zaznamená jméno, aktuální hodnotu a novou hodnotu proměnné
- `COOKIE_ACCEPTED` - akceptování cookie na web stránce
- `COOKIE_REJECTED` - zamítnutí použití cookies na web stránce
- `CRON` - zaznamená běh úkolů na pozadí, pokud je zaškrtnuta možnost Auditovat. Ukládá i chyby při vykonávání úkolů (pokud nastanou), v takovém případě zaznamená `Stack Trace`.
- `DATA_DELETING` - zaznamenává provedení mazání dat v Nastavení-Mazání dat. Zaznamená klíč který se v cache smazal, nebo `ALL` pro smazání všeho. Při mazání cache obrázků zaznamená cestu k adresáři. Při mazání persistent cache zaznamená ID záznamu.
- `DMAIL` - aplikace Hromadný email
- `DMAIL_AUTOSENDER` - používá se ve speciální situaci automatického odesílání hromadného emailu
- `DMAIL_BLACKLIST` - změna v Hromadný email->Odhlášené e-maily
- `DMAIL_DOMAINLIMITS` - změna v Hromadný email->Doménové limity
- `EXPORT_WEBJET` - nepoužívá se
- `EXPORT` - operace v aplikaci Export dat (přidání, změna, smazání exportu dat)
- `FILE_CREATE` - vytvoření souboru nebo adresáře, zaznamená cestu
- `FILE_DELETE` - smazání souboru nebo adresáře, zaznamená cestu
- `FILE_EDIT` - přejmenování, nebo editace souboru, zaznamená cestu
- `FILE_SAVE` - uložení souboru, například. při jeho kopírování / přesouvání a podobně. Zaznamená cestu k souboru
- `FILE_UPLOAD` - nahrání souboru do WebJETu, ať už přes klasické nahrání, nebo Drag & Drop. Typicky zaznamenává cestu k nahranému souboru.
- `FORMMAIL` - odeslání formuláře. Zaznamená úspěšné odeslání s hlášením `FormMail formName:` jméno formuláře, seznam příjemců a `referer`. Při neúspěchu zaznamená důvod ne odeslání s hlášením `ERROR: formName:` jméno formuláře, `fail:` důvod ne odeslání. Zaznamenává i detekci spamu hlášením `detectSpam TRUE:` důvod detekce jako spam.
- `FORM_ARCHIVE` - archivace formuláře, zaznamená jméno formuláře
- `FORM_DELETE` - smazání formuláře, zaznamená jméno formuláře a případně ID pokud se jedná o smazání jednoho záznamu

- `FORM_EXPORT` - export formuláře přes záložku Exportovat, aktuálně se nezaznamenává univerzální export přes tlačítka pod tabulkou. Podle tohoto záznamu se určuje datum posledního exportu pro možnost exportu od posledního exportu.
- `FORM_REGEXP` - změna v Formuláře->Regulární výrazy
- `FORM_VIEW` - nepoužívá se
- `FORUM_SAVE` - zaznamená detekci vulgarismu v diskusním fóru
- `FORUM` - operace v aplikaci Diskuse
- `GALLERY` - změny v aplikaci Galerie - vytvoření adresáře, přidání/smazání fotky
- `GDPR_FORMS_DELETE` - aplikace GDPR, mazání starých formulářů
- `GDPR_USERS_DELETE` - aplikace GDPR, mazání starých uživatelů
- `GDPR_BASKET_INVOICES_DELETE` - aplikace GDPR, mazání starých objednávek z elektronického obchodu
- `GDPR_EMAILS_DELETE` - aplikace GDPR, mazání starých emailů
- `GDPR_REGEXP` - aplikace GDPR, správa regulárních výrazů
- `GDPR_DELETE` - aplikace GDPR, nastavení mazání dat
- `GDPR_COOKIES` - aplikace GDPR, správa cookies
- `GROUP` - vytvoření / uložení / smazání adresáře v sekci Web stránky
- `HELPDESK` - nepoužívá se
- `HELP_LAST_SEEN` - používá se k evidenci data zobrazení sekce Co je nového v nápovědě. Při přihlašování se v této sekci hledá nejnovější soubor a porovnává se vůči zaznamenanému datu v Auditu. Pokud existuje novější soubor, zobrazí se po přihlášení vyskakovací okno nápovědy se sekcí Co je nového.
- `IMPORTXLS` - importu Excel souboru, používá se v zákaznických implementacích. Zaznamenává cestu k importovanému souboru a jeho velikost
- `IMPORT_WEBJET` - nepoužívá se
- `INIT` - inicializace WebJETu (start), zaznamenává cestu k adresáři ve kterém byl WebJET na aplikačním serveru spuštěn a číslo verze WebJETu
- `INQUIRY` - operace v aplikaci Anketa
- `INQUIRY` - přidání otázky v aplikaci Anketa, zaznamená text otázky
- `INSERT_SCRIPT` - změna v aplikaci Skripty
- `INVENTORY` - operace v aplikaci Majetek
- `JSPERROR` - chyba při provádění JSP souboru při zobrazení web stránky, zaznamená `Stack Trace` chyby
- `MEDIA` - operace s Médiemi (karta Média ve web stránce).
- `MEDIA_GROUP` - aplikace správa skupin médií.
- `PAGE_DELETE` - smazání, přesun do koše nebo požádání o smazání stránky, zaznamená ID stránky
- `PAGE_UPDATE` - zaznamenává změny ve stránce mimo standardní uložení v editoru - hromadné operace v seznamu stránek
- `PAYMENT_GATEWAY` - volání platební brány v aplikaci Elektronický obchod
- `PEREX_GROUP_CREATE` - vytvoření perex skupiny, zaznamená její jméno
- `PEREX_GROUP_DELETE` - smazání perex skupiny, zaznamená její jméno a ID
- `PEREX_GROUP_UPDATE` - změna perex skupiny, zaznamená její jméno
- `PERSISTENT_CACHE` - změna v Mazání dat->Persistent cache objekty
- `PROP_DELETE` - smazání překladového textu, zaznamená jazyk a klíč
- `PROP_UPDATE` - editace překladového textu (v sekci Nastavení), zaznamená jazyk, klíč a hodnotu
- `PROXY` - operace v aplikaci proxy
- `QA` - operace v aplikaci Otázky a odpovědi
- `REDIRECT_CREATE` - vytvoření nového přesměrování (url nebo domény)
- `REDIRECT_DELETE` - smazání přesměrování (url nebo doména), zaznamená zdroj a pro doménu i cíl přesměrování
- `REDIRECT_UPDATE` - změna přesměrování (url nebo domény), zaznamená zdrojovou a cílovou adresu
- `RUNTIME_ERROR` - zaznamená chybějící šablonu pro zobrazení stránky
- `SAVEDOC` - uložení web stránky v Editoru, zaznamenává i žádosti o schválení. Zaznamenává titulek stránky, ID stránky a ID v historii
- `SENDMAIL` - odeslání emailu (mimo formulářů), zaznamená email odesílatele, příjemce a předmět emailu
- `SE_SITEMAP` - generování souboru `/sitemap.xml`, zaznamená ID adresáře pro který se mapa stránky generuje a obsah hlavičky User-Agent
- `SQLERROR` - databázová chyba, zaznamená SQL chybu, zdroj chyby a `Stack Trace`
- `TEMPLATE_DELETE` - smazání šablony, zaznamená jméno smazané šablony
- `TEMPLATE_INSERT` - vytvoření nové šablony, zaznamená její jméno

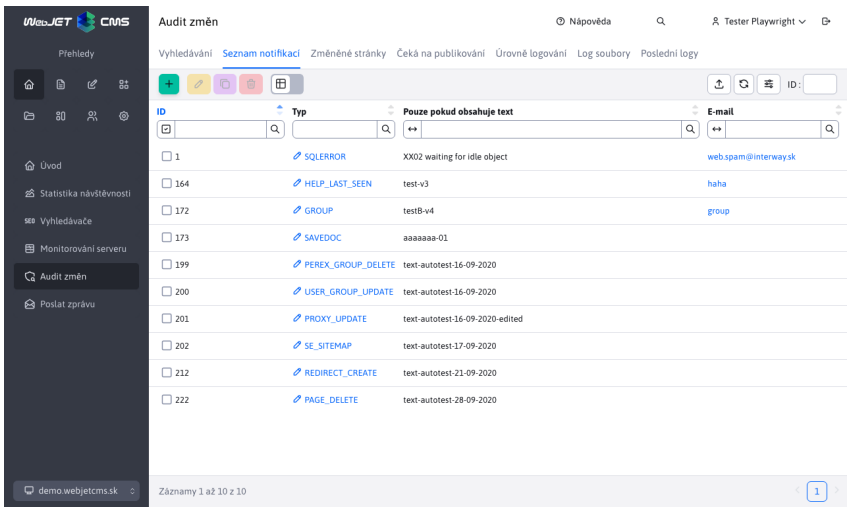
- `TEMPLATE_UPDATE` - změna v šabloně, zaznamená seznam změněných polí
- `TEMPLATE_GROUP` - změna ve skupině šablon
- `TIP` - operace v aplikaci Tip dne
- `TOOLTIP` - změna v aplikaci Tooltip
- `UPDATEDB` - provedení změny v databázi přes admin konzoli
- `USER_AUTHORIZE` - autorizace uživatele (schválení přístupu do zaheslované sekce). Zaznamenává ID smazaného uživatele, pokud je známo i jeho `login` a jméno.
- `USER_CHANGE_PASSWORD` - audituje změnu hesla uživatele. Na základě data se počítá interval změny hesla (je-li nastaven)
- `USER_DELETE` - smazání uživatele. Zaznamenává ID smazaného uživatele, pokud je známo i jeho `login` a jméno.
- `USER_EDIT` - zaznamená událost otevření editace uživatele, nejedná se ještě o jeho uložení. Zaznamená ID uživatele, `login` a jméno.
- `USER_GROUP_DELETE` - smazání skupiny uživatelů, zaznamená jméno skupiny a její ID
- `USER_GROUP_INSERT` - vytvoření nové skupiny uživatelů, zaznamená jméno nové skupiny a její typ
- `USER_GROUP_UPDATE` - uložení skupiny uživatelů, zaznamená jméno skupiny a seznam změn
- `USER_INSERT` - vytvoření nového uživatele (nebo nová registrace v zaheslované sekci). Zaznamená ID uživatele, `login` a jméno.
- `USER_LOGOFF` - odhlášení uživatele kliknutím na ikonu odhlášení, zaznamená přihlašovací jméno a informaci o tom, zda se jedná o administrátora nebo registrovaného návštěvníka
- `USER_LOGON` - přihlášení uživatele, zaznamená přihlašovací jméno a informaci o tom, zda se jedná o administrátora nebo registrovaného návštěvníka. Zaznamená i událost zadání neplatného hesla, pokud uživatel není autorizovaný nebo přihlašovací jméno je neznámé
- `USER_PERM_GROUP` - operace se skupinami práv, zaznamená jméno skupiny a při změně seznam změn
- `USER_SAVE` - zaznamenává změny v uživateli v zaheslované sekci (pokud obsahuje formulář pro změnu údajů)
- `USER_UPDATE` - uložení stávajícího uživatele. Zaznamenává aktuální nastavení práv a změny v zadaných údajích
- `WEB_SERVICES` - volání zákaznických `WebServices` (použití záleží na implementaci pro konkrétního zákazníka)
- `XSRF` - XSRF útok na server (nepovolený referer header), zaznamená hodnotu doménového jména z `referer` hlavičky
- `XSS` - XSS útok na server nebo přímé (nepovolené) volání JSP souboru. Zaznamená URL adresu nebo výraz kvůli kterému se útok vyhodnotil (např. nepovolený token v URL, nepovolené HTTP metoda). Zaznamenává také ukradení cookie (změna IP adresy session).

6. Speciální formát auditu

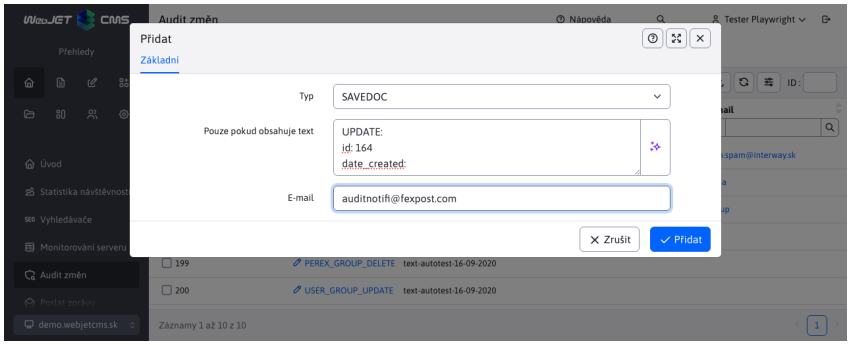
V případě potřeby je možné do WebJETu doplnit kód, který audit záznamy bude ukládat do speciálního souboru, nebo posílat na určenou službu. Je třeba nastavit konf. proměnnou `adminlogCustomLogger` na Java třídu, která implementuje třídu `sk.iway.iwcm.AdminlogCustomLogger`. Při každém zápisu se jmenuje metoda `addLog(logType, requestBean, descriptionParam, timestamp)`

7. Seznam notifikací

V menu položce Seznam notifikací lze nastavit email notifikace při určitých událostech / chybách systému. Doporučujeme nastavit notifikaci pro události typu `XSS` a `SQLERROR`.



V editoru lze nastavit i doplňkový text, který chyba musí obsahovat, aby byla odeslána na zadaný email.

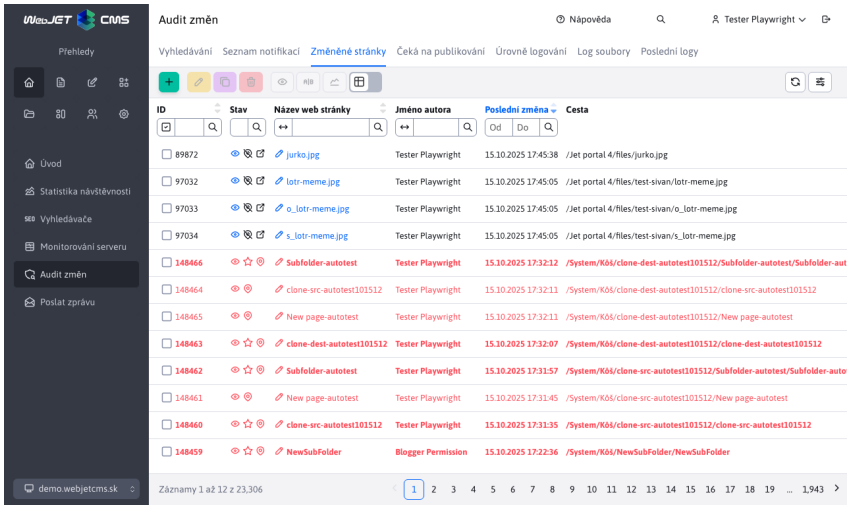


Jako email odesílatele se použije email příjemce. V případě potřeby je možné nastavit jméno a email odesílatele všech emailů notifikací auditu pomocí konfiguračních proměnných `auditDefaultSenderName` a `auditDefaultSenderEmail`.

8. Změněné stránky

V menu položce Změněné stránky je vidět seznam změněných stánek, seřazený od poslední změněné. S těmito stránkami umíte pracovat stejně jako v sekci Seznam web stránek (https://docs.webjetcms.sk/latest/cs/redactor/webpages/README).

Zobrazeny jsou všechny stránky bez ohledu na práva uživatele na stromovou strukturu stránek a zvolenou doménu.



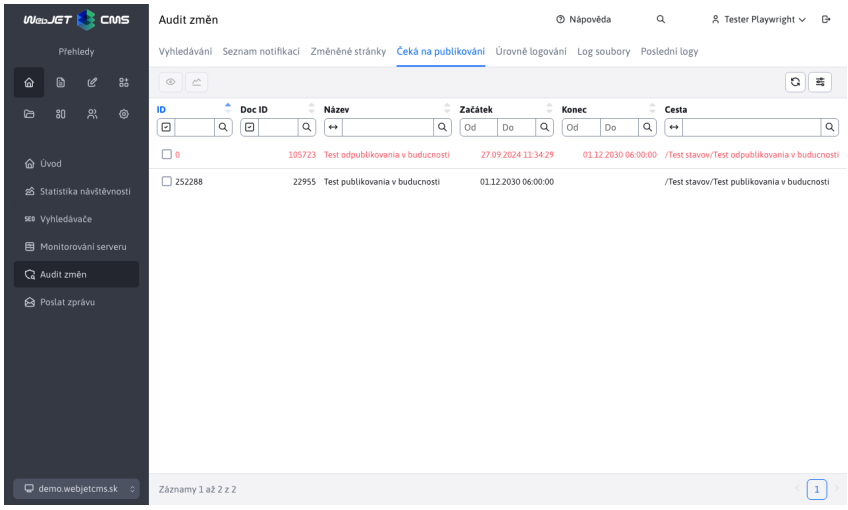
9. Čeká na publikování

V menu položce Čeká na publikování je seznam stránek, které mají v budoucnu naplánované publikování. Obsahuje informace o tom o jakou web stránku (na jaké adrese/cestě) a kdy se bude publikovat. Bližší informace o web stránkách naleznete zde Seznam web stránek (https://docs.webjetcms.sk/latest/cs/redactor/webpages/README).

Cílem je přehledně zobrazit seznam stránek, které v budoucnu budou automaticky změněny. Zobrazeny jsou všechny stránky bez ohledu na práva uživatele na stromovou strukturu stránek a zvolenou doménu.

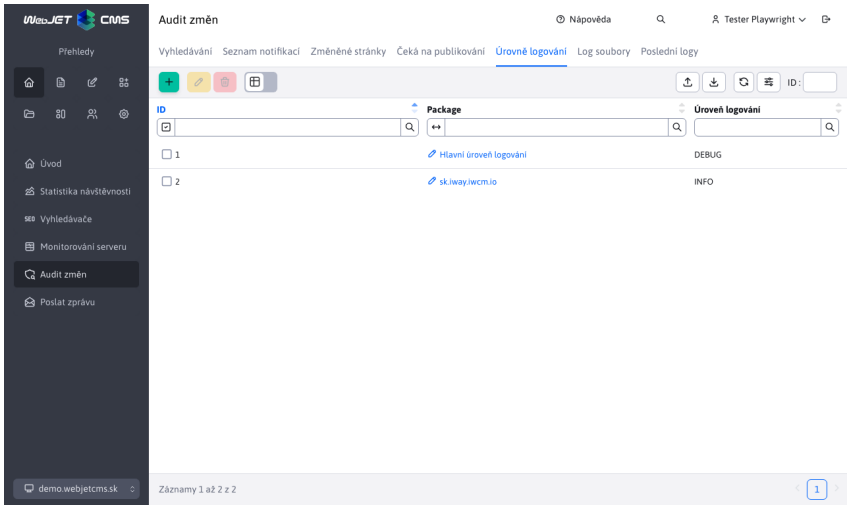
Červenou barvou jsou zobrazeny web stránky, které čekají na vypnutí zobrazování – mají nastavenou možnost Odveřejnit stránku po tomto datu. Takové stránky po nastaveném datu nebudou veřejně zobrazitelné.

V seznamu se nezobrazují stránky v koši, pro ty se publikování neprovádí.



10. Úrovně logování

Aplikace Úrovně logování umožňuje správu úrovni logování pro jednotlivé java balíčky.



První záznam v tabulce je vždy **Hlavní úroveň logování** (základní úroveň).

Využívají se 2 konfigurační proměnné:

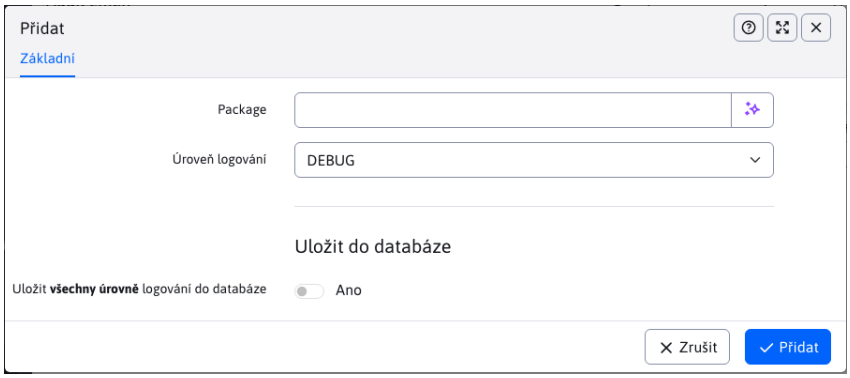
- **logLevel**, obsahuje hodnotu úrovně logování pro **Hlavní úroveň logování**
- **logLevels**, obsahuje seznam java balíků s úrovní logování (každý na novém řádku). Např.:

```
sk.iway=DEBUG
sk.iway.iwcm=WARN
org.springframework=WARN
```

Změny nad tabulkou jsou uchovávány lokálně v konstantě. Pokud změny (nastavení) chcete uložit permanentně, v editoru je třeba zvolit možnost **Uložit do databáze**. Při uložení se aktualizují zmíněné konfigurační proměnné v databázi.

11. Přidání

Při akci přidání je potřebná hodnota java balíku (package) a úrovně logování. Pokud zadáte již přidaný package, nevytvoří se duplicitní hodnota, ale aktualizuje se již existující.



12. Editace

Akce editace se chová rozdílně pro Hlavní úroveň logování a ostatní logování.

12.1. Hlavní úroveň logování

Při editaci hlavní úrovně můžeme zvolit pouze logování typu NORMAL nebo DEBUG (pro podrobné logování). Pokud v editoru změníte hodnotu `Package`, žádná změna se neprovede. Jelikož hlavní úroveň musí být stále přítomna, změnit lze pouze hodnotu úrovně logování.

12.2. Ostatní logování

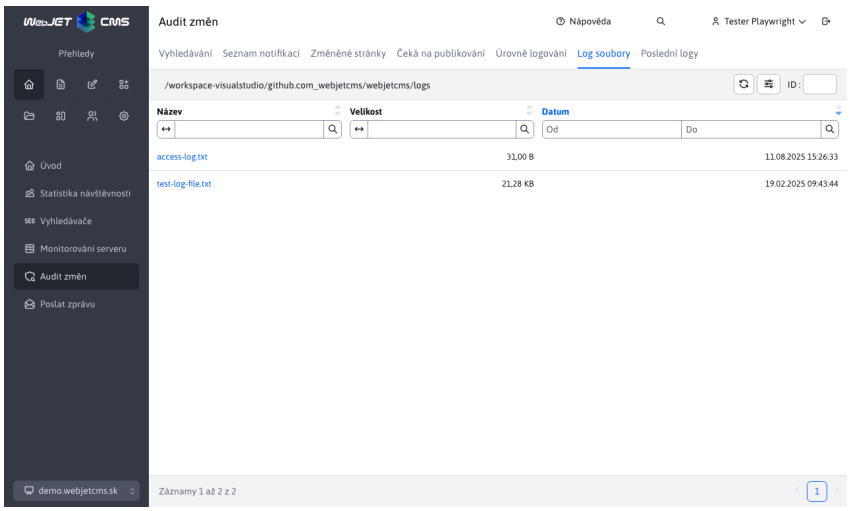
Změna úrovně logování se uloží, pokud změníte package, původní logování zmizí a bude nahrazeno tímto novým. Povoleny jsou všechny úrovně logování kromě hodnoty NORMAL.

13. Mazání

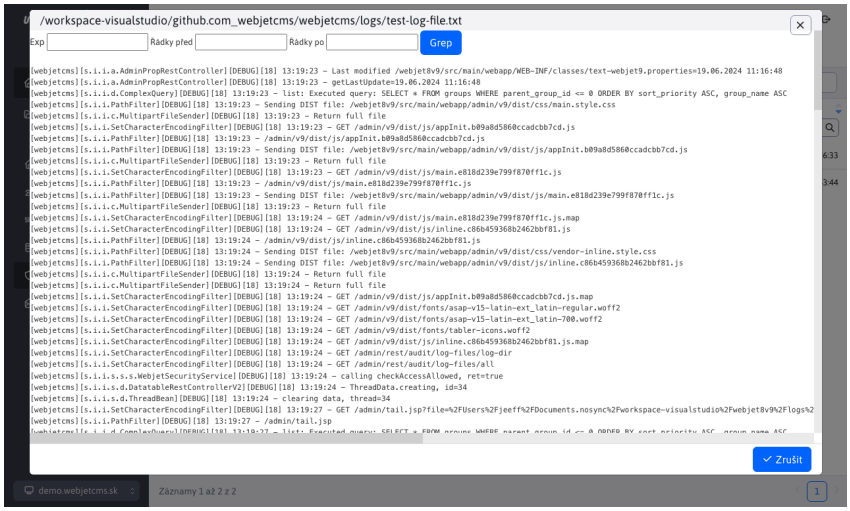
Všechny packages s úrovní logování lze vymazat kromě **Hlavní úrovně logování**. Při pokusu o vymazání se nic s ní nestane (ani hodnota se nezmění).

14. Log soubory

Aplikace poskytuje přehled všech log souborů. Úpravy nad tabulkou nejsou povoleny. Tabulka slouží pouze k přehledu. V levé horní části stránky, můžete vidět cestu, kde jsou tyto soubory uloženy.

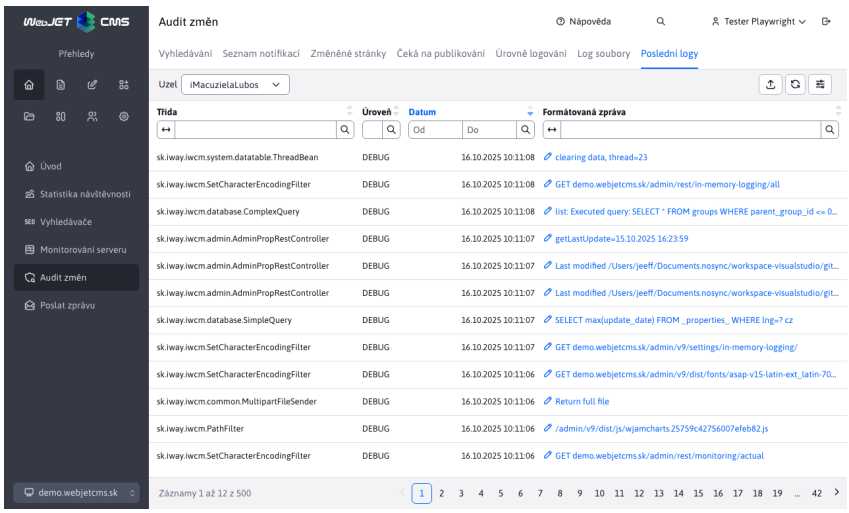


Při klepnutí na název souboru se zobrazí okno s obsahem souboru. Hlavička obsahuje pole pro možnost filtrování v souboru pomocí regulárních výrazů (nebo přímo pouze vyhledaným výrazem).



15. Poslední logy

Aplikace je určena k zobrazení posledních logů, v případě, že nemáte přístup k logům na souborovém systému. Zobrazuje logy, které procházejí přes log framework (čili používají třídu `Logger`), nezobrazí logy zapsané přímo přes `System.out` nebo `System.err`.



Podporuje cluster, je tak možné vyžádat i poslední logy z jiného uzlu clusteru. V kartě `Stack Trace` se nachází výpis zásobníku (obsah se ale zobrazí pouze pro chybové záznamy, pro standardní log úrovně je prázdný).

15.1. Konfigurační možnosti/nastavení:

- `loggingInMemoryEnabled` - nastavením na `true/false` povolíte nebo zakážete ukládání logů do paměti.
- `loggingInMemoryQueueSize` - maximální počet logů zapsaných do paměti (výchozí 200). Upozorňujeme, že všechna data jsou načtena najednou do tabulky a z důvodu přenosu `stack trace` mohou být velké. Nedoporučujeme tuto proměnnou nastavovat na extrémně vysokou hodnotu.

Pro správné fungování musí být `logger` nastaven iv souboru `logback.xml`. Ve výchozím nastavení je takto nastaven, pokud jste ale soubor měnili, je třeba doplnit `IN_MEMORY appender` a přidat jeho volání pro `root` element.

```xml
...
<appender name="IN_MEMORY" class="sk.iway.iwcm.system.logging.InMemoryLoggerAppender" />

<root level="ERROR">
    <appender-ref ref="STDOUT" />
    <appender-ref ref="IN_MEMORY" />
</root>
...
```

15.2. Implementační detaily

- `sk.iway.iwcm.system.logging.InMemoryLoggerAppender` - `appender` pro `logback`, který zajišťuje odeslání logů do `InMemoryLoggingDB`
- `sk.iway.iwcm.system.logging.InMemoryLoggingDB` - třída zajišťuje zápis a získání logů z a do `queue`, načítání logů na clusteru
- `sk.iway.iwcm.system.logging.InMemoryLoggingEvent` - model pro log event
- `sk.iway.iwcm.system.logging.InMemoryLoggerRestController` - controller pro výpis logů do DataTable

16. Výkon serveru

Pro optimální výkon serveru je potřeba splnit několik požadavků a nastavení. Každá vložená aplikace (např. foto galerie, anketa atd.) do web stránky způsobuje zpomalení. Aplikace typicky provádějí dodatečné databázové požadavky, nebo potřebují číst data ze souborového systému.

Výrazný vliv na výkon mohou mít také vyhledávače, které neustále procházejí a indexují web stránky na vašem serveru. Jejich návštěvnost nemusí být vidět například. v Google Analytics, ale je vidět v statistice (https://docs.webjetcms.sk/latest/cs/redactor/apps/stat/README), kterou poskytuje WebJET CMS.

16.1. Identifikace problémů

Jako první je třeba identifikovat místa, kde dochází ke zpomalení. Pokud umíte na první pohled identifikovat web stránku, která se vám zdá pomalá, můžete použít URL parametr `?_writePerfStat=true`. Jinak zapněte monitorování serveru, ve kterém umíte identifikovat web stránky, které jsou prováděny nejdéle.

16.1.1. URL parametrem

Pomocí URL parametru `?_writePerfStat=true` je možné získat výpis aplikací vložených ve web stránce s časem jejich provedení. Například stránku `/sk/` zobrazíte jako `/sk/?_writePerfStat=true`.

Při takovém zobrazení web stránky se do HTML kódu vloží po každé aplikaci výraz typu `PerfStat: 3 ms (+3) !INCLUDE(...)`. Ve standardně zobrazené webové stránce nemusí být dobře dohledatelný, proto doporučujeme zobrazit zdrojový kód stránky - v Chrome menu Zobrazit-Vývojář-Zobrazit zdrojový kód. Následně použijte vyhledávání v prohlížeči výrazu `PerfStat:`.

Tento výraz je ve formátu `PerfStat: 3 ms (+3)` kde první číslo znamená celkový čas provedení jednoho `iwcm:write` výrazu a číslo v závorce je čas provedení této aplikace. Následně následuje cesta k aplikaci a její parametry. Vás tedy zajímá primární číslo v závorce.

Pomocí URL parametru `_disableCache=true` lze vypnout vyrovnávací paměť aplikací.

16.1.2. Monitorování serveru

Pro komplexní pohled můžete zapnout funkci monitorování serveru nastavením následujících konfiguračních proměnných:

- `serverMonitoringEnable` - zapne funkci monitorování serveru a zaznamenávání hodnot
- `serverMonitoringEnablePerformance` - zapne funkci monitorování výkonu aplikací a web stránek
- `serverMonitoringEnableJPA` - zapne funkci monitorování SQL požadavků

> **Upozornění:** monitorování výkonu aplikací a SQL požadavků zatěžuje server, nedoporučujeme mít tuto funkci permanentně zapnutou.

Po nastavení konfiguračních proměnných je třeba provést **restart aplikačního serveru**, aby se při inicializaci aktivovalo sledování výkonu.

Následně v sekci Monitorování serveru - Aplikace/WEB stránky/SQL dotazy umíte identifikovat části, které se dlouho provádějí. Zaměřte se na nejčastěji prováděné aplikace/SQL dotazy a jejich optimalizaci.

16.1.3. Celkový čas generování web stránky

Existuje aplikace `/components/_common/generation_time.jsp` kterou pokud vložíte do patičky šablony web stránky vygeneruje do HTML kódu celkovou dobu generování web stránky.

Lze nastavit následující parametry aplikace:

- `hide` - ve výchozím nastavení `true` - čas generování se zobrazí jako komentář v HTML kódu
- `onlyForAdmin` - ve výchozím nastavení `false` - čas generování se zobrazí jen pokud je přihlášen administrátor

Do patičky (nebo vhodného volného pole) šablony web stránky vložte následující kód:

```html
!INCLUDE(/components/_common/generation_time.jsp, hide=true, onlyForAdmin=false)!
```

Na místě vložené aplikace se zobrazí informace o době provedení celé web stránky v ms:

```html
<!-- generation time: 4511 ms -->
```

16.2. Měření výkonu databázového serveru a souborového systému

Pro srovnání výkonu prostředí testovací VS produkční prostředí lze použít níže uvedené skripty. Jejich spuštění vyžaduje právo na aktualizaci WebJET. Měřit a porovnávat prostředí můžete bez zátěže, ale i během provozu nebo výkonnostních testů.

- `/admin/update/dbspeedtest.jsp` - měří výkon čtení údajů z databázového serveru.

Dobré hodnoty jsou například:

```html
Image read, count=445
...
Total time: 649 ms, per item: 1.4584269662921348 ms
Total bytes: 4.8050469E7, per second: 7.403770261941448E7 B/s

Random web page read, count=3716
...
Total time: 3608 ms, per item: 0.9709364908503767 ms
Total bytes: 1371566.0, per second: 380145.78713968955 B/s

Only documents.data web page read, count=3716
...
Total time: 2205 ms, per item: 0.5933799784714747 ms
Total bytes: 685783.0, per second: 311012.6984126984 B/s

Documents read using web page API, count=3716
...
Total time: 1869 ms, per item: 0.5029601722282023 ms
Total bytes: 685783.0, per second: 366925.09363295883 B/s
```

Z důvodu rozdílného počtu záznamů v databázi je třeba srovnávat `per item` hodnoty.

- `/admin/update/fsspeedtest.jsp` - kontroluje rychlost čtení seznamu souborů ze souborového systému, je třeba ověřit hlavně pokud používáte síťový souborový systém.

Dobré hodnoty jsou například:

```html
Testing mime speed, start=0 ms
has base file object, fullPath=/Users/jeeff/Documents.nosync/workspace-visualstudio/webjet/webjet8v9-
hotfix/src/main/webapp/components/_common/mime diff=1 ms
listFiles, size=678, diff=284 ms
listing done, diff=16 ms


Testing modinfo speed, start=0 ms
modinfo list, size=102, diff=1 ms
modinfo listing done, diff=220 ms
Total time=522ms
```

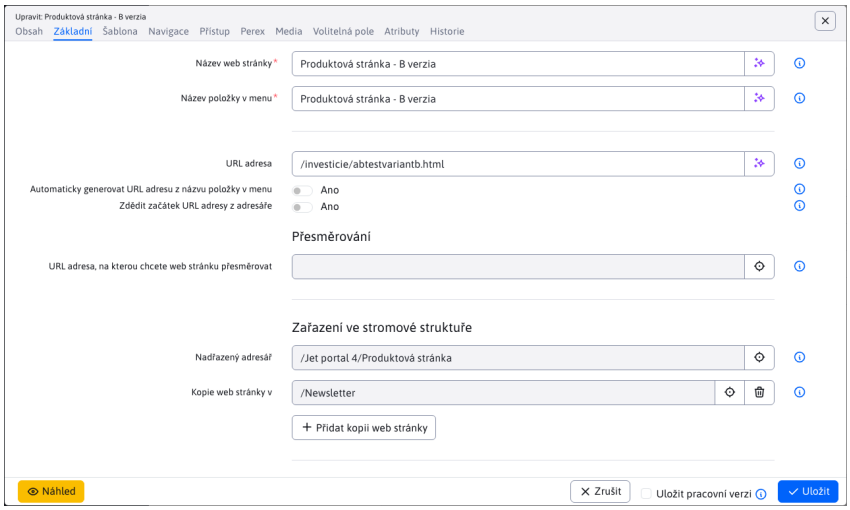
16.3. Optimalizace databázových požadavků

Optimalizovat počet databázových požadavků lze zapnutím vyrovnávací paměti - `cache`.

16.3.1. Web stránky

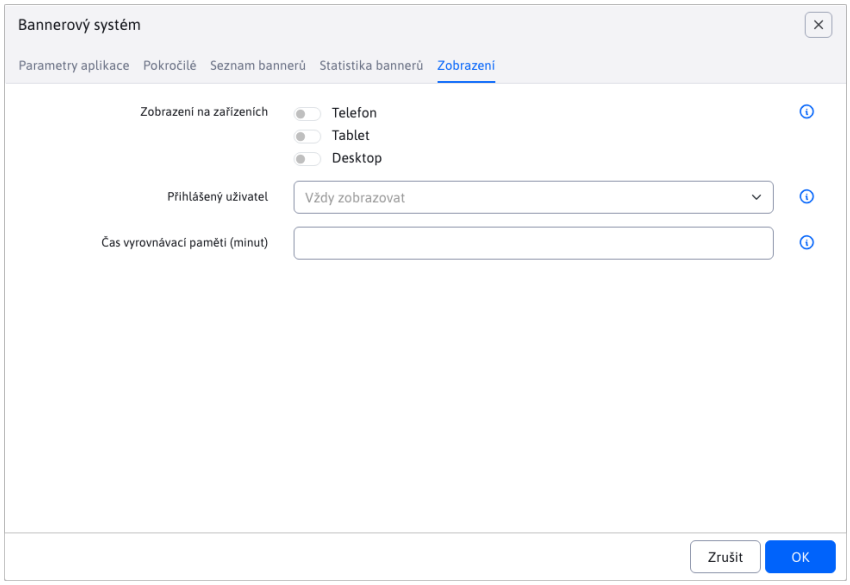
Každá web stránka má v kartě Základní možnost **Povolit uložení stránky do vyrovnávací paměti**. Zapnutím této možnosti se obsah web stránky z tabulky `documents` uloží do vyrovnávací paměti. Při zobrazení web stránky nebude nutné provést databázové volání pro získání obsahu web stránky.

Tuto možnost doporučujeme zapnout na nejvíce navštěvovaných web stránkách, jejichž seznam získáte v aplikaci statistika (https://docs.webjetcms.sk/latest/cs/redactor/apps/stat/README).



16.3.2. Aplikace

Podobně jako pro web stránky lze zapnout vyrovnávací paměť i pro aplikace. Některé aplikace mají tuto možnost dostupnou přímo v nastavení aplikace (https://docs.webjetcms.sk/latest/cs/custom-apps/appstore/README) vložené ve web stránce v kartě Zobrazení jako pole **Čas vyrovnávací paměti**.



Pokud aplikace toto nastavení nemá dostupné stále můžete parametr nastavit v HTML kódu textu web stránky přidáním parametru `, cacheMinutes=xxx` k parametrům vložené aplikace, například:

```html
!INCLUDE(sk.iway.iwcm.components.reservation.TimeBookApp, reservationObjectIds=2560+2561, device=,
cacheMinutes=10)!
```

Upozornění: je třeba si uvědomit, že vyrovnávací paměť je globální pro celý aplikační server. Jako klíč se použije cesta k souboru aplikace, jednotlivé parametry zadané v HTML kódu web stránky a jazyk aktuálně zobrazené web stránky. Neberou se v úvahu URL parametry web stránky.

Vyrovnávací paměť nelze tedy použít například pokud se zobrazí například stránkování seznamu kde číslo strany se přenáší pomocí URL parametru. Aby ale bylo možné uložit seznam novinek existuje výjimka – pro aplikace obsahující v názvu souboru `/news/news` se použije vyrovnávací paměť pouze pokud v URL adrese není zadán parametr `page`, respektive hodnota tohoto parametru je jiná než `1`. Takto se vyrovnávací paměť použije i pro seznam novinek, ale uloží se do ní jen první strana výsledků. Další strany nejsou ukládány.

16.4. Optimalizace souborového systému

Web stránky typicky obsahují spoustu doplňkových souborů – obrázky, CSS styly, JavaScript soubory a podobně, které je třeba spolu s web stránkou načíst. Rychlost zobrazení tedy závisí i na počtu a velikosti těchto souborů.

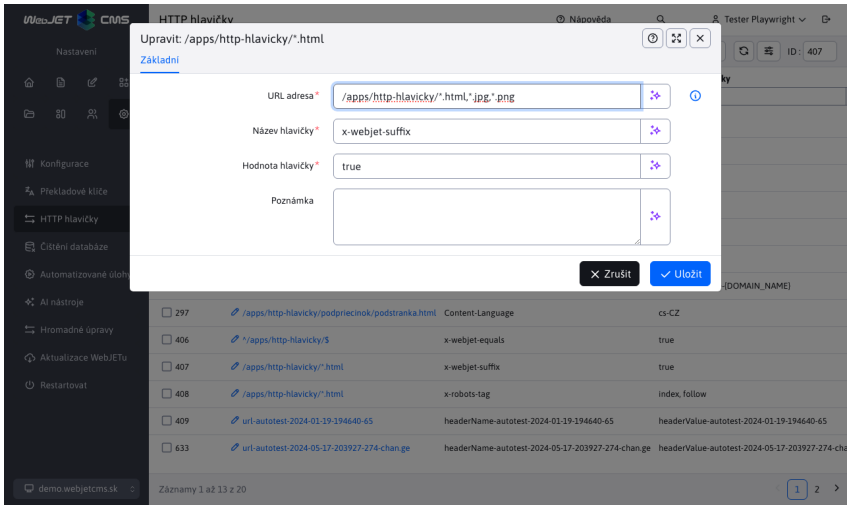
16.4.1. Nastavení vyrovnávací paměti

Pro soubory web stránky lze nastavit použití vyrovnávací paměti v prohlížeči - soubor se tak nebude opakovaně číst při každém zobrazení web stránky, ale pokud jej již má prohlížeč ve vyrovnávací paměti, tak se použije. Zrychlí se tak zobrazení web stránky a sníží zátěž na server. Příkladem je obrázek loga, který je typicky na každé stránce, ale jeho změna je vysoce nepravděpodobná – respektive mění se řádově jednou za několik měsíců.

Lze nastavit následující konfigurační proměnné, které ovlivňují HTTP hlavičku `Cache-Control`:

- `cacheStaticContentSeconds` - nastavený počet sekund, ve výchozím nastavení `300`.
- `cacheStaticContentSuffixes` - seznam přípon, pro které se HTTP hlavička `Cache-Control` vygeneruje, ve výchozím nastavení `.gif,.jpg,.png,.swf,.css,.js,.woff,.svg,.woff2`.

Pro přesnější nastavení lze použít aplikaci HTTP hlavičky (https://docs.webjetcms.sk/latest/cs/admin/settings/response-header/README), kde můžete nastavit rozdílné hodnoty pro rozdílné URL adresy.



16.5. Chování pro administrátora

Pokud je přihlášen administrátor vyrovnávací paměť pro aplikace se nepoužije (předpokládá se, že administrátor vždy chce vidět aktuální stav).

Toto chování lze změnit nastavením konfigurační proměnné `cacheStaticContentForAdmin` na hodnotu `true`. Vhodné je tuto hodnotu nastavit hlavně pro intranet instalace, kde se uživatelé ověřují vůči `SSO/ActiveDirectory` serveru ai při běžné práci v intranet prostředí mají práva administrátora.

16.6. Vyhledávače

Vyhledávače a různé jiné roboty mohou výrazně zatížit server. Zvláště s nástupem učení umělé inteligence dochází k výraznému prohledávání internetu a plnění databází pro učení umělé inteligence. Roboty často zkoušejí různé URL parametry pro získání dodatečných dat.

16.6.1. Nastavení robots.txt

Chování robotů lze ovlivnit nastavením v souboru `/robots.txt`. Tento pokud neexistuje je generován ve výchozím stavu. Vámi upravenou verzi umístěte do `/files/robots.txt`, z tohoto webu jej WebJET zobrazí při volání `/robots.txt`.

Pomocí souboru robots.txt (https://en.wikipedia.org/wiki/Robots.txt) můžete ovlivnit chování robotů a vyhledávačů - omezit URL adresy, které mohou použít, nastavit odstup mezi požadavky atp.

16.7. Ostatní nastavení

16.7.1. Reverzní DNS server

Statistika, audit a další aplikace mohou získávat reverzní DNS záznam z IP adresy. Používá se API volání `InetAddress.getByName(ip).getHostName()`. Na serverech/v DMZ nemusí ale být DNS server dostupný a toto volání může trvat několik sekund než nastane chyba. Obecně takové volání zpomaluje provedení HTTP požadavku.

Nastavením konfigurační proměnné `disableReverseDns` na hodnotu `true` je možné vypnout získávání DNS názvu z IP adresy návštěvníka a zrychlit provádění požadavků. Do pole pro hodnotu `hostname` se tehdy zapíše hodnota IP adresy.

16.7.2. Vypnutí statistiky

Zapisování údajů statistiky je asynchronní, provádí se v dávkách tak, aby zobrazení web stránky nečekalo na zápis údajů statistiky do databáze.

Při vysoké návštěvnosti nebo hledání problémů s výkonem můžete dočasně vypnout zapisování statistik návštěvnosti nastavením konfigurační proměnné `statMode` na hodnotu `none`. Standardní hodnota je `new`.

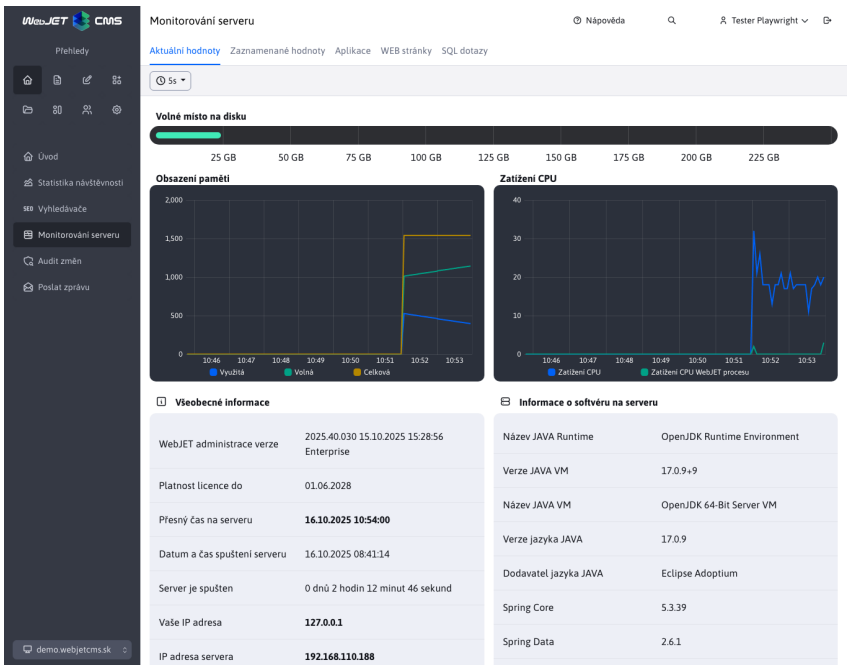
17. Monitorování serveru

17.1. Vnitřní monitorování

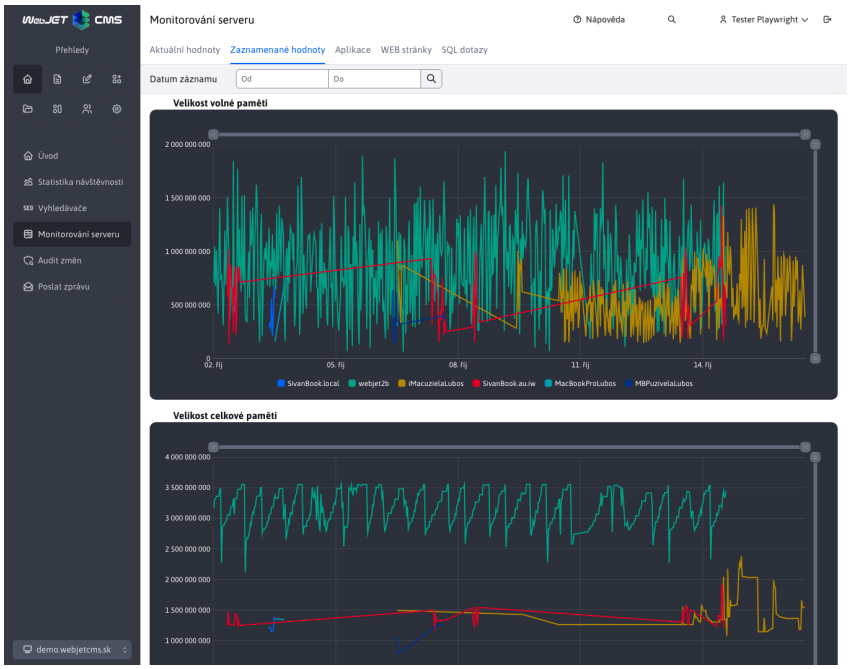
Analýza výkonu a zátěže serveru, jednotlivých aplikací, databázových dotazů a samotných stránek lze sledovat přímo v aplikaci Monitorování serveru (v administraci WebJETu v sekci Přehled).

Modul poskytuje následující možnosti:

- **Aktuální hodnoty** - aktuální hodnoty zatížení serveru, paměti a počet databázových spojení.



- **Zaznamenané hodnoty** - výpis historických zaznamenaných hodnot využití paměti, `sessions`, cache a spojení s databází. Pro ukládání historických hodnot je třeba nastavit konf. proměnnou `serverMonitoringEnable` na hodnotu `true`.



Po nastavení konfigurační proměnné `serverMonitoringEnablePerformance` na `true` jsou dostupné také:

- **Aplikace** - statistika provedení jednotlivých aplikací. Zobrazuje počet provedení, průměrný čas provedení, počet provedení z cache paměti a nejpomalejší provedení.
- **WEB stránky** - statistika zobrazení jednotlivých web stránek. Zobrazuje počet zobrazení, průměrný čas zobrazení, nejpomalejší a nejrychlejší zobrazení.

Po nastavení konfigurační proměnné `serverMonitoringEnableJPA` na `true` je dostupné také:

- **SQL dotazy** - statistika rychlosti provádění SQL dotazů. Zobrazuje počet provedení, průměrný čas provedení, nejpomalejší a nejrychlejší provedení a samotný SQL dotaz.

Upozornění: aktivace monitorování má vliv na výkon serveru a jeho paměťové zatížení. Kromě možnosti zaznamenané hodnoty má zapnutí monitoringu dopad na výkon serveru. Všechny údaje kromě části zaznamenané hodnoty jsou drženy pouze v paměti serveru, takže po jeho restartu se začnou evidovat nově.

Upozornění: modulové možnosti **Aplikace**, **WEB stránky** a **SQL dotazy** využívají jedinečnou společnou logiku, která je blíže popsána v Monitorování serveru podle vybraného uzlu

17.2. Vzdálené monitorování běhu serveru

Pokud potřebujete monitorovat stav WebJETu přes Nagios (http://www.nagios.org) /Zabbix (https://www.zabbix.com) nebo jinou službu, WebJET poskytuje na URL adrese `/components/server_monitoring/monitor.jsp` svůj stav. Odpovídá HTTP **stavem 200 je-li vše v pořádku**, nebo **stavem 500** (Internal Server Error) pokud **nejsou splněny všechny kontroly**.

Uvedenou URL adresu lze volat i v sekundových intervalech, doporučujeme ji používat i v rámci clusteru pro monitorování dostupnosti jednotlivých nodů.

Povolené IP adresy, pro které monitor.jsp korektně odpovídá se nastavují v konfigurační proměnné `serverMonitoringEnableIPs`.

Součást monitoruje následující části:

- **Inicializace WebJETu**, včetně jeho `preheating` (čekání na inicializaci cache objektů nebo úloh na pozadí). Čas preheating se nastavuje v konf. proměnné monitoringPreheatTime (výchozí 0). WebJET odpovídá textům `NOT INITIALISED` pokud není korektně inicializován (např. není vůbec konektivita do databáze při jeho startu, nebo má neplatnou licenci). Textem `TOO SHORT AFTER START` odpovídá během preheating času (zařazení do clusteru by mělo čekat na dokončení načtení cache objektů/úkolů na pozadí).
- Monitorování **dostupnosti databázového spojení** - provádí se SQL select z tabulky `documents` (konkrétně `SELECT title FROM documents WHERE doc_id=?`), přičemž v konfigurační proměnné `monitorTestDocId` je docid testované stránky. Pokud se SQL dotaz nepodaří odpovídá textům `DEFAULT DOC NOT FOUND`.
- **Dostupnost šablon** - je-li seznam inicializovaných šablon menší než 3 odpovídá textům `NOT ENOUGHT TEMPLATES`.
- **Zápis údajů statistiky** - ověřuje, že v zásobníku zápisu statistik není podezřele mnoho záznamů (jejich počet se nastavuje v konfigurační proměnné `statBufferSuspicionThreshold`, ve výchozím nastavení 1000). Pokud zásobník zápisu statistik obsahuje větší množství údajů k zápisu indikuje to buď problém s výkonem SQL serveru, nebo problém s úlohami na pozadí. V případě překročení počtu záznamů odpovídá textům `STAT BUFFER SUSPICION`.
- Pokud nastane **jiná chyba** odpovídá textům `EXCEPTION: xxxx`.

WebJET je možné i manuálně **přepnout do servisního režimu** nastavením konfigurační proměnné `monitorMaintenanceMode` na true. Tehdy monitor.jsp odpovídá textům `UNAVAILABLE`.

Je-li vše v pořádku odpovídá textem `OK`. Pro monitorování **postačuje sledovat HTTP stav** odpovědi, text je pouze informační pro přesnější určení problému.

17.3. Konfigurační proměnné

- `serverMonitoringEnable` - pokud je nastaveno na `true`, spouští monitorování serveru každých 30 sekund a zapisuje tyto hodnoty do tabulky `monitoring`
- `appendQueryStringWhenMonitoringDocuments` - zachycovat při monitorování i SQL parametry `?`
- `monitorTestDocId` - ID stránky, jejíž databázové spojení (získání názvu) se testuje v komponentě `/components/server_monitoring/monitor.jsp` kterou může testovat dohledový SW (výchozí hodnota: 1)
- `serverMonitoringEnablePerformance` - pokud je nastaveno na `true`, spouští monitorování rychlosti SQL dotazů, web stránek a aplikací (výchozí hodnota: false)
- `serverMonitoringEnableJPA` - pokud je nastaveno na `true`, spouští monitorování rychlosti provádění SQL dotazů pro JPA, má ale za následek zvýšení zátěže na paměť serveru (výchozí hodnota: false)

- `serverMonitoringEnableIPs` - Seznam IP adres ze kterých je dostupná komponenta `monitor.jsp` pro monitorování serveru (výchozí hodnota: 127.0.0.1,192.168.,10.,62.65.161.,85.248.107.,195.168.35.)
- `monitoringPreheatTime` - Počet vteřin potřebných pro zahřátí web sídla (načtení cache) po restartu, během kterého bude `monitor.jsp` komponenta vracet nedostupnost uzlu clustra (výchozí hodnota: 0)
- `monitoringEnableCountUsersOnAllNodes` - Pokud veřejné uzly clusteru nemají možnost zapisovat do tabulky `_conf_/webjet_conf` nastavte na hodnotu `false`. Celkový počet `sessions` bude pak dostupný jen součtem z jednotlivých záznamů v monitorování serveru.

18. Restartovat

Klepnutím na možnost **Restartovat** v sekci Nastavení se vám zobrazí potvrzení restartu WebJETu. Restart se systémově provede na serveru, avšak záleží na nastavení serveru, zda je restart z web aplikace povolen. Pokud ne, restart se neprovede.

V konfiguraci `server.xml` aplikačního serveru Tomcat (https://tomcat.apache.org/tomcat-9.0-doc/config/context.html) je třeba mít povolen restart pomocí atributu `reloadable="true"` v elementu `Context`:

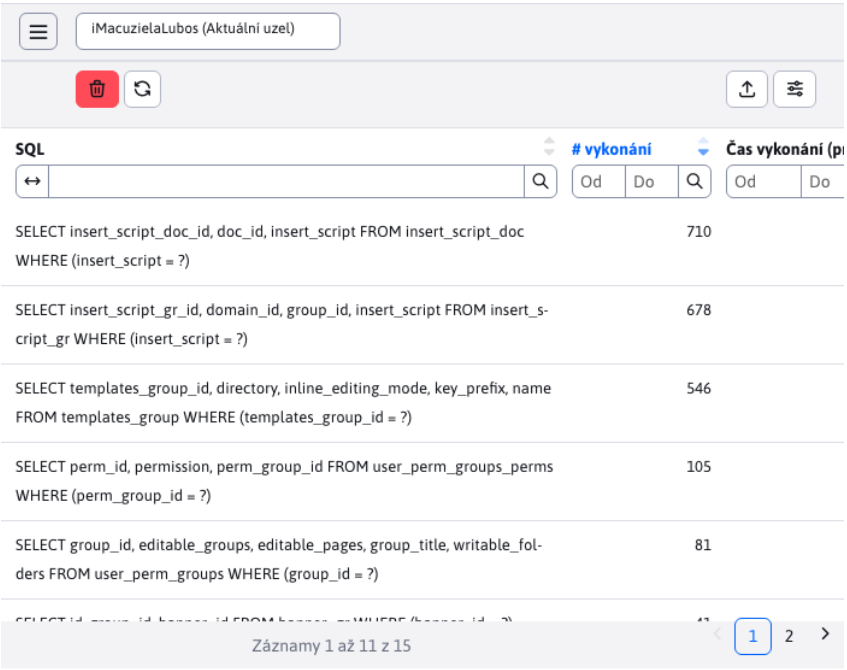
```xml
<Host name="...">
    <Context reloadable="true" />
</Host>
```

> **Upozornění:** Před restartem si ověřte dostupnost technické podpory vašeho hostingu, protože může být nutné restartovat i aplikační server. To však nelze provést přímo z prostředí WebJETu.

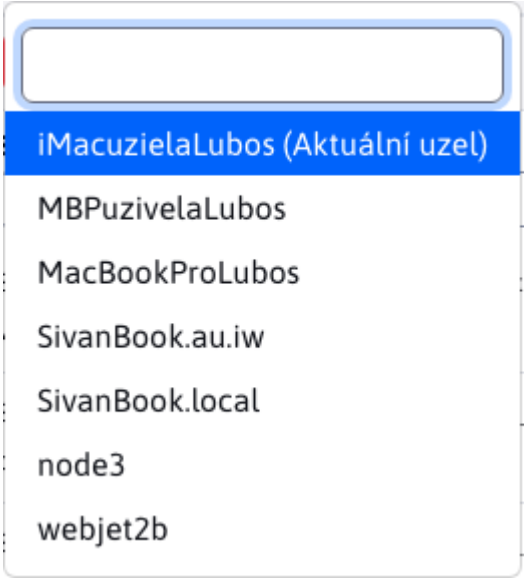
Opakovaným restartem se může také zaplnit paměť aplikačního serveru, což může vyžadovat restart aplikačního serveru přímo na serveru.

19. Výměna údajů uzlů clusteru

Stránky **Aplikace**, **WEB stránky** a **SQL dotazy** sdílejí stejnou logiku ohledně monitorování serveru podle aktuálně zvoleného uzlu. K výběru uzlu slouží pole, které se nachází v záhlaví stránky vedle názvu stránky.



Po otevření klikem, můžeme vidět všechny dostupné možnosti. Přednastavená hodnota je vždy aktuální uzel (uzel clusteru na který jste právě přihlášen), který je označen textem `(Aktuálny uzol)`.



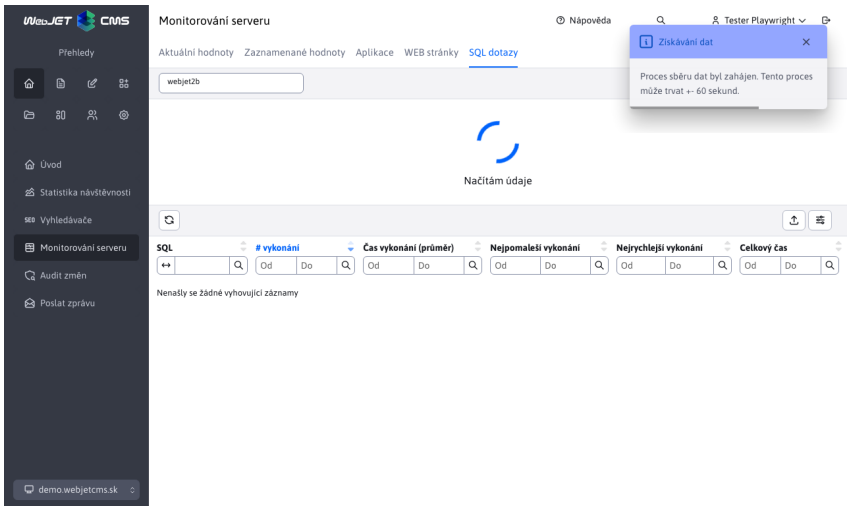
Pokud je zvolený uzel aktuální, zobrazují se lokálně uložená data. V tomto případě je také k dispozici i tlačítko vymazání, které odstraní tato lokálně uložená data (tlačítko vymazání je dostupné pouze v případě aktuálního uzlu). V případě jiného než aktuálního uzlu se data získávají z databázové tabulky.

19.1. Obnovení dat - aktuální uzel

Pokud je zvolen aktuální uzel, tak po stisku tlačítka obnovení údajů se pouze získají aktuálně uložená data (nepracuje se zde s databázovými tabulkami). Pokud byla data dříve vymazána, může chvíli trvat než se tam objeví nové záznamy.

19.2. Obnovení dat - vzdálený uzel

V případě jiných uzlů, než aktuálních, je obnovení dat složitější. Data jiných uzlů jsou uložena v tabulce `cluster_monitoring`. Proces obnovení dat začíná vymazáním těchto dat z tabulky, jelikož již nemusí být aktuální.



Jak je vidět na obrázku výše, data byla odstraněna a zobrazí se animace čekající na data. Také vidíme informační notifikaci, která nás upozorňuje, že tento proces může trvat +- několik vteřin. Tento interval se může lišit v závislosti na nastavené konfigurační proměnné `clusterRefreshTimeout`.

Proces získání aktuálních dat spočívá ve vytvoření požadavku o aktuální data pro nějaký uzel vytvořením záznamu v databázové tabulce `cluster_refresher`. Samotný cluster v intervalech zadaných konf. proměnnou `clusterRefreshTimeout` aktualizuje data v tabulce

`cluster_monitoring` pro konkrétní uzel, existuje-li pro tento uzel žádost v tabulce `cluster_refresher`. Proto proces získávání dat může trvat i několik minut a může se lišit v závislosti na nastaveném intervalu obnovování clusteru (může nastat i situace, kdy cluster interval byl těsně před obnovením a aktuální data získáme za 10 sekund, i když interval byl nastaven na 5 minut).

Sice to není zobrazeno, ale stránka se bude každých 10 sekund dotazovat, zda do tabulky `cluster_monitoring` nebyla přidána nová data, která by mohla být zobrazena. V případě, že požadovaný uzel neobsahoval žádná data (ale tabulka již byla aktualizována), vytvoří se nový cluster požadavek o data, a opět budeme každých 10 vteřin kontrolovat, zda se tato data již aktualizovala. Celý proces se bude opakovat, dokud aktualizovaná tabulka `cluster_monitoring` nebude obsahovat alespoň jeden záznam k zobrazení. V té chvíli se skryje animace a aktuálně získaná data jiného uzlu jsou zobrazena.

20. Mazání dat

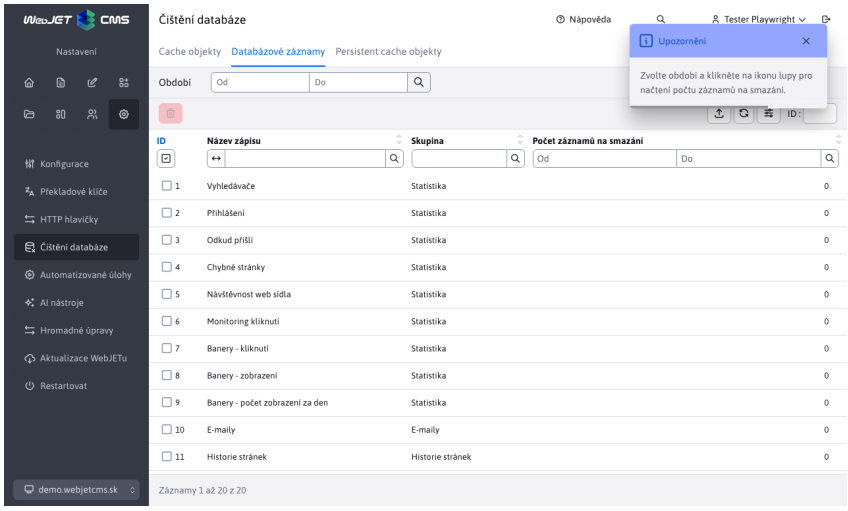
Aplikace **Mazání dat** vám umožňuje odstranit nepotřebná data z databáze, čímž můžete zvýšit výkon serveru a uvolnit místo na disku. Tento nástroj naleznete v sekci **Nastavení** pod položkou **Mazání dat**.

20.1. Databázové záznamy

Mazání dat z vybraných databázových tabulek, mazání je možné z následujících skupin:

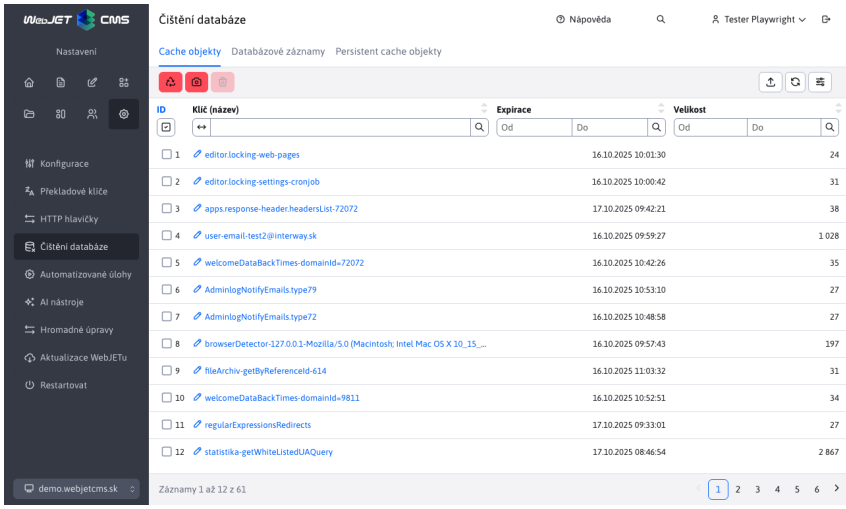
- **Statistika**: Odstraňuje statistická data. Smazání starších dat může významně zlepšit výkon serveru, ztratíte ale informace o návštěvnosti webu za zvolené období.
- **E-maily**: Umožňuje odstranit odeslané e-maily z aplikace Hromadný e-mail a emaily odeslané s časovým zpožděním (případně emaily odeslané v rámci více uzlového clusteru).
- **Historie stránek**: Maže zaznamenané historické verze webových stránek, ty se ukládají při každém publikování web stránky. Jsou zobrazeny v kartě Historie při editaci web stránky. Smazání neovlivní aktuálně zobrazené stránky, smažou se historické verze.
- **Monitorování serveru**: Odstraňuje zaznamenaná data z monitorování serveru, jako jsou výkonnostní metriky a logy.
- **Audit**: Maže záznamy auditu, které monitorují aktivity uživatelů a systémové události, smazat lze pouze vybrané typy záznamů.

Při každém smazání se provádí i optimalizace dané databázové tabulky, aby se fyzicky uvolnilo místo na disku a optimalizovalo se pořadí záznamů v databázové tabulce.



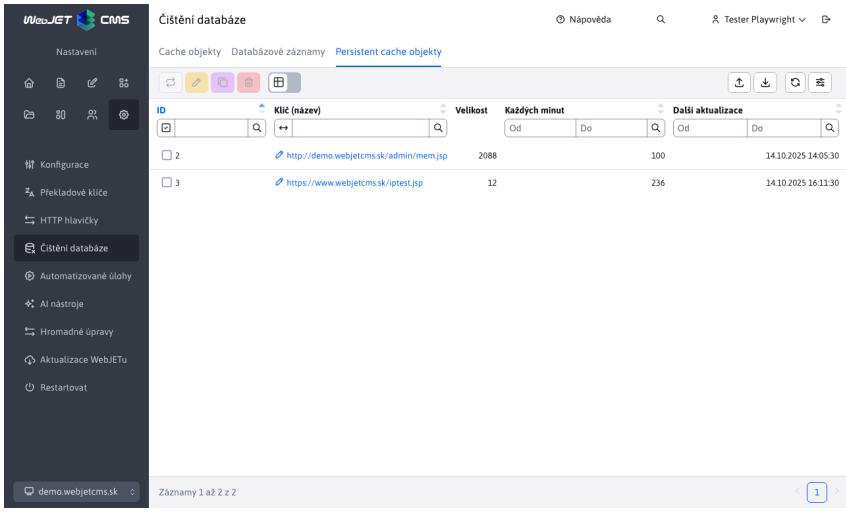
20.2. Cache objekty

Zobrazuje seznam objektů uložených v aplikační cache paměti a umožňuje jejich jednotlivé vymazání, čímž můžete snížit spotřebu paměti, nebo vyvolat obnovení dat v cache paměti serveru. Klepnutím na název lze pro vybrané datové typy zobrazit obsah záznamu. Pro práci se používá objekt Cache (https://github.com/webjetcms/webjetcms/tree/main/src/webjet8/java/sk/iway/iwcm/Cache.java)



20.3. Persistent cache objekty

Správa a mazání objektů uložených v trvalé cache paměti, která uchovává data i po restartu serveru (údaje jsou uloženy v databázi). Pro práci se používá objekt PersistentCacheDB (https://github.com/webjetcms/webjetcms/tree/main/src/webjet8/java/sk/iway/iwcm/system/cache/PersistentCacheDB.java). Do této cache lze ukládat pouze textová data, typicky se využívá metoda `downloadUrl(String url, int cacheInMinutes)` která na pozadí stahuje data ze zadané URL adresy a aktualizuje je v nastaveném čase. Aplikace používá tuto metodu a ihned získává data z cache.



21. Nastavení licenčního čísla

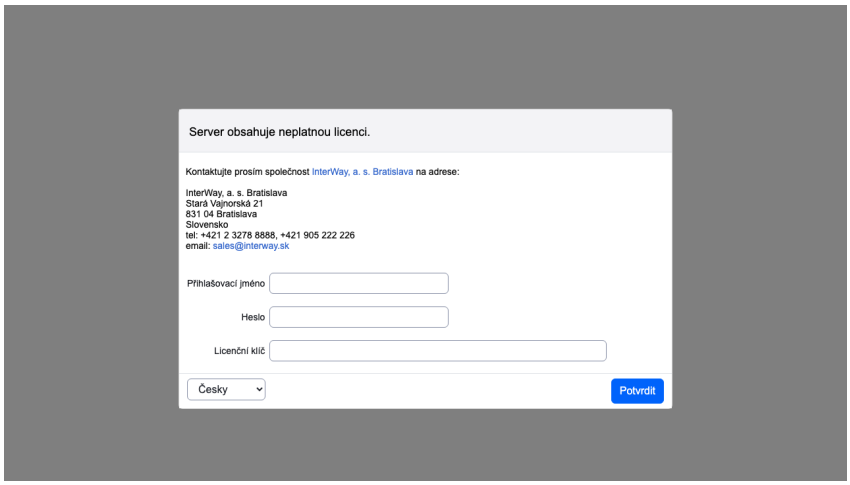
Licenční číslo pro WebJET se zadává v sekci Nastavení/Konfigurace do konf. proměnné `lisense`. K hlavní licenci je možné mít nastaveny doplňkové licence pro další domény (např. při použití Enterprise licence) v konf. proměnné `licenseDomains` kde se zadává každá doplňková licence domény na nový řádek.

21.1. Nesprávné licenční číslo

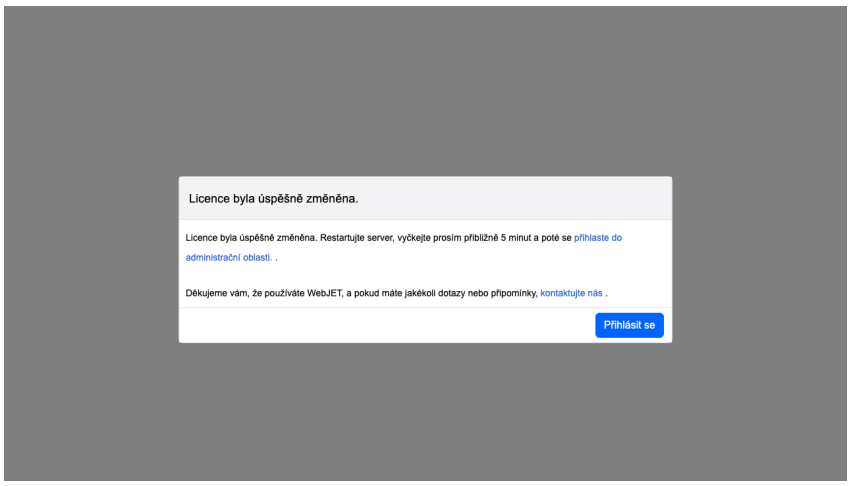
Pokud WebJET obsahuje licenční číslo s exspirovaným datem platnosti, nesprávným doménovým jménem, nebo licenční číslo je nesprávně zadané, zobrazí se po přihlášení do administrace možnost aktualizovat licenční číslo, v logech serveru se při startu zobrazí:

```log
[webjet][s.i.i.InitServlet][INFO][0] 2023-10-02 09:27:30 - ----------------------------------------------
[webjet][s.i.i.InitServlet][INFO][0] 2023-10-02 09:27:30 - WebJET initializing, root:
/www/tomcat/webapps/webjet
[webjet][s.i.i.InitServlet][INFO][0] 2023-10-02 09:27:30 -
[webjet][s.i.i.InitServlet][INFO][0] 2023-10-02 09:27:30 - VERSION: 9
[webjet][s.i.i.InitServlet][INFO][0] 2023-10-02 09:27:30 - Checking database connection:
[webjet][s.i.i.InitServlet][INFO][0] 2023-10-02 09:27:30 -    Database connection: [OK]
[webjet][s.i.i.InitServlet][INFO][0] 2023-10-02 09:27:30 - INIT (db): license=xxxxxxxxxxxxxxxxxxxxxxxxxxxxxx
[webjet][s.i.i.InitServlet][INFO][0] 2023-10-02 09:27:30 - License is valid until: 01.06.2022 23:59:59
[webjet][s.i.i.InitServlet][INFO][0] 2023-10-02 09:27:30 - ERROR: License is out of date, please contact
  InterWay (www.interway.sk)
  for new license.
```

Pokud se možnost zadat licenční číslo nezobrazí automaticky po otevření administrační části otevřete adresu `/wjerrorpages/setup/license`.



Zadejte přihlašovací údaje pro ověření oprávnění do administrace a nový licenční klíč. Klepněte na OK pro uložení. Zobrazí se potvrzení uložení:



Pokud se aplikační server nerestartuje automaticky, proveďte restart aplikačního serveru. Při novém startu se použije zadané licenční číslo.

21.2. Zadání licenčního čísla přímo do databáze

V případě nemožnosti zadání licenčního čísla přes web rozhraní můžete použít následující SQL příkaz přímo na databázovém serveru:

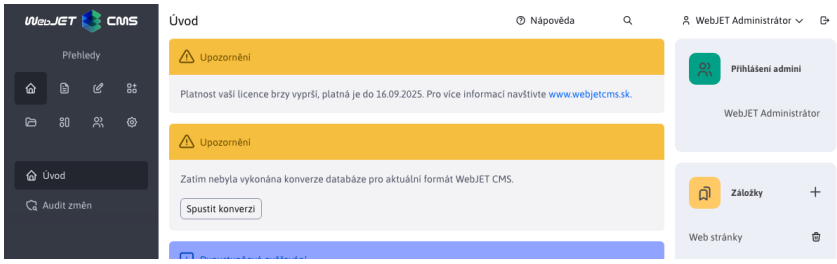
```sql
UPDATE _conf_ SET value='xxx' WHERE name='license';
```

pro Oracle použijte zápis:

```sql
UPDATE webjet_conf SET value='xxx' WHERE name='license';
```

21.3. Exspirace licence

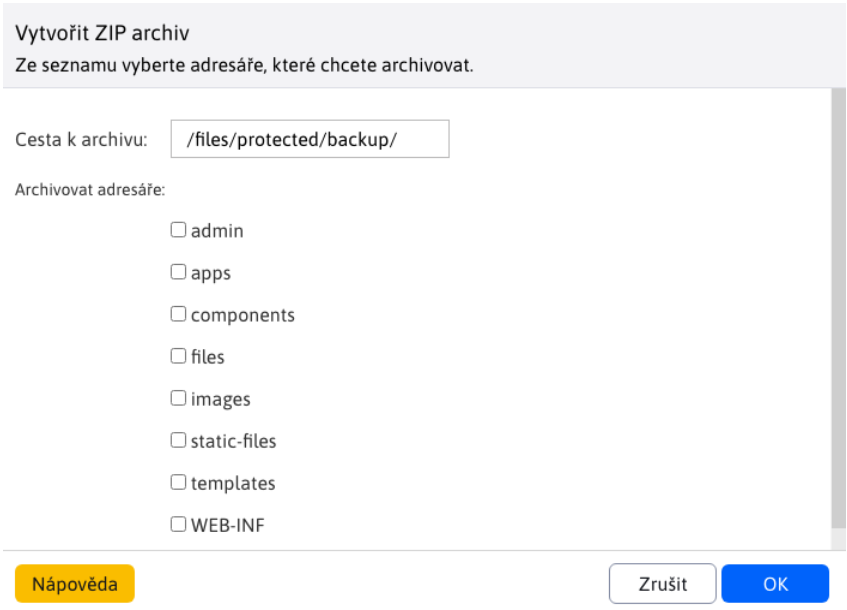
WebJET umí automaticky zjistit blížící se konec platnosti Vaše licence. Pokud zjistí, že platnost licence vyprší do 2 (nebo méně) měsíců, zobrazí upozornění v úvodní části.



22. Zálohování systému

Aplikace slouží k vytvoření ZIP archiv jednotlivých složek souborového systému WebJET. Můžete zvolit, které složky se do ZIP archivu mají zahrnout a do které složky se má vytvořit výsledný ZIP archiv. Nevytváří se záloha databáze, tu je třeba vytvořit nástroji pro zálohování databází.

> **Upozornění:** Objem dat ve zvolených složkách může být velký a ZIP soubor se nemusí vygenerovat správně (omezení je na 2GB soubor). V případě potřeby můžete vytvářet zálohy po částech (jednotlivých složkách).



Tento proces může trvat několik desítek minut podle objemu dat ve zvolených složkách. Čekejte, až celý proces skončí. Během toho by se vám v okně měla zobrazovat informace o počtu již vygenerovaných stránek ao celkovém počtu stránek.

Výsledkem je zip archiv vytvořený v zadané složce.